

UNIVERSITY OF CRETE

UNIVERSITY OF CRETE / ΠΑΝΕΠΙΣΤΗΜΙΟ ΚΡΗΤΗΣ

Πτυχιακή Εργασία

Machine learning for network traffic analysis in cybersecurity

Μηχανική Μάθηση για ανάλυση κίνησης δικτύου στην Κυβερνοασφάλεια

Ημερομηνία: Ιούνιος 2026

Φοιτητής: **Γαραζανάκης Κωνσταντίνος**

Επιβλέπων Καθηγητής: **Χάρης Μανιφάβας**

Περίληψη

Η παρούσα πτυχιακή εργασία διερευνά την εφαρμογή τεχνικών Μηχανικής Μάθησης στην Ανάλυση Δικτυακής Κίνησης (Network Traffic Analysis, εφεξής NTA), με στόχο την ενίσχυση της Κυβερνοάμυνας και την αντιμετώπιση σύγχρονων και πολύπλοκων απειλών. Αξιοποιώντας το σύνολο δεδομένων CIC-IDS2017, πραγματοποιήθηκε εκτενής προεπεξεργασία, καθώς και εξαγωγή και επιλογή χαρακτηριστικών, αναδεικνύοντας τις 15 υψηλότερα βαθμολογημένες δικτυακές μεταβλητές στο παρόν πείραμα. Στο πλαίσιο της Επιβλεπόμενης Μάθησης, συγκρίθηκαν διάφοροι αλγόριθμοι (Random Forest, Decision Trees, k-NN, Logistic Regression, MLP), με τα δενδρικά μοντέλα να επιτυγχάνουν τη βέλτιστη απόδοση υπό συνθήκες αξιολόγησης κλειστού κόσμου (>99.7%), ενώ παράλληλα αναδείχθηκαν οι περιορισμοί γενίκευσης (~49%) υπό αυστηρό χρονικό διαχωρισμό σε μή-εμφανισθείσες επιθέσεις. Επιπλέον, εξετάστηκε η χρονική μοντελοποίηση για τον εντοπισμό επιθέσεων όγκου (DDoS), ενώ αναλύθηκαν οι επιχειρησιακές προκλήσεις της Μη Επιβλεπόμενης Μάθησης σε σχέση με το φαινόμενο της κόπωσης των ειδοποιήσεων. Ιδιαίτερη έμφαση δόθηκε και στην Επεξηγηματική Τεχνητή Νοημοσύνη (Explainable AI - XAI). Μέσω της ενσωμάτωσης του αλγορίθμου SHAP, παρουσιάστηκε έμπρακτα η διαφάνεια των αλγοριθμικών αποφάσεων, επιτρέποντας την τοπική επεξήγηση σε περιβάλλοντα Κέντρων Επιχειρήσεων Ασφάλειας (SOC). Τέλος, αναλύθηκε η ευπάθεια των μοντέλων μέσω προσομοίωσης επιθέσεων αποφυγής και προτάθηκε μια ρεαλιστική αρχιτεκτονική ανάπτυξης σε πραγματικό χρόνο, σε μια προσπάθεια γεφύρωσης του χάσματος μεταξύ της θεωρητικής ακαδημαϊκής έρευνας και της πρακτικής επιχειρησιακής εφαρμογής.

Λέξεις-Κλειδιά: Κυβερνοασφάλεια, Μηχανική Μάθηση, Ανάλυση Δικτυακής Κίνησης, Εντοπισμός Ανωμαλιών, Επεξηγηματική Τεχνητή Νοημοσύνη.

Abstract

This thesis investigates the application of Machine Learning techniques in Network Traffic Analysis (NTA) to enhance Cyber Defense against modern and complex threats. Utilizing the CIC-IDS2017 dataset, extensive data preprocessing, feature extraction, and feature selection were conducted, highlighting the 15 highest-ranked network variables in this experimental setup. Within the framework of Supervised Learning, various algorithms were compared (Random Forest, Decision Trees, k-NN, Logistic Regression, MLP), with tree-based models achieving optimal performance under a closed-world shuffled baseline evaluation (>99.7%), while a strict time-aware split (~49%) highlighted the generalization limits against unseen future attacks. Furthermore, time-based modeling was examined for the detection of volumetric attacks (DDoS). The operational challenges of Unsupervised Learning, particularly regarding the Alert Fatigue phenomenon, were also analyzed. Special emphasis was placed on Explainable AI (XAI). By integrating the SHAP algorithm, the transparency of algorithmic decisions was ensured, allowing for local explanations in Security Operations Center (SOC) environments. Finally, model vulnerability was analyzed through the simulation of evasion attacks (Adversarial ML / Red Teaming), and a realistic real-time deployment architecture was proposed, bridging the gap between theoretical academic research and practical operational application.

Keywords: Cybersecurity, Machine Learning, Network Traffic Analysis, Anomaly Detection, Explainable AI.

Πίνακας Περιεχομένων

Περίληψη..... 2
Abstract.....3
Πίνακας Περιεχομένων..... 4
Κεφάλαιο 1: Εισαγωγή.....6
Κεφάλαιο 2: Υπόβαθρο και Μεθοδολογία..... 7
2.1 Σύντομη Βιβλιογραφική Ανασκόπηση.....7
2.2 Μετάβαση από Παρατηρήσεις Επιπέδου Πακέτου (Packet-Level) σε Επίπεδο Ροής (Flow-Level)..... 7
2.3 Εξαγωγή Στατιστικών Χαρακτηριστικών (Feature Extraction).....7
2.4 Μεθοδολογία και Εργαλεία.....9
2.5 Προκλήσεις και Στρατηγική Προεπεξεργασίας Δεδομένων (Preprocessing Pipeline)10
2.5.1 Συντακτικός Καθαρισμός και Δομικές Ασυνέπειες..... 10
2.5.2 Διαχείριση Ακραίων Τιμών (Infinity) και Ελλειπουσών Εγγραφών (NaN)..... 10
2.5.3 Αξιολόγηση Ταξικής Ανισορροπίας:..... 13
2.5.4 Αποφυγή Διαρροής Πληροφορίας και Κανονικοποίηση.....13
2.5.5 Χρονικά Ενήμερος Διαχωρισμός (Time-Aware Splitting)..... 14
Κεφάλαιο 3: Ανάλυση, Επιλογή Χαρακτηριστικών και Διερευνητική Οπτικοποίηση.....15
3.1 Η "Κατάρα της Dimensionality"..... 15
3.2 Επιλογή Χαρακτηριστικών μέσω Αλγορίθμου Τυχαίου Δάσους (Random Forest).....16
3.3 Ερμηνεία των Σημαντικότερων Δικτυακών Μεταβλητών.....18
3.3.1 Περιορισμοί Επιλογής Χαρακτηριστικών..... 19
3.4 Μείωση Διαστάσεων και Οπτικοποίηση (PCA).....20
3.5 Υπολογιστικές Προκλήσεις κατά το PCA.....20
Κεφάλαιο 4: Εκπαίδευση και Συγκριτική Αξιολόγηση Μοντέλων.....22
4.1 Θεωρητικό Υπόβαθρο Αλγορίθμων Μηχανικής Μάθησης.....22
4.1.1 Δέντρα Απόφασης (Decision Trees)..... 22
4.1.2 Τυχαία Δάση (Random Forest).....22
4.1.3 K-Κοντινότεροι Γείτονες (K-Nearest Neighbors - k-NN)..... 23
4.1.4 Λογιστική Παλινδρόμηση (Logistic Regression).....24
4.1.5 Επιβλεπόμενη Μάθηση (Supervised Learning) στην Ταξινόμηση Κίνησης..... 24
Το Πρόβλημα του Data Shift και οι Κίνδυνοι του Cross-Validation.....25
Hyperparameter Tuning και Εξαγωγή Baseline Μετρικών..... 26
4.2 Μη Επιβλεπόμενη Μάθηση και Ανίχνευση Ανωμαλιών..... 30
4.2.1 Θεωρητικές Προσεγγίζεις και η Επιλογή του Isolation Forest.....30
4.2.2 Εκπαίδευση, Κατώφλια και Προκλήσεις των Δεδομένων.....30
4.2.3 Επιχειρησιακή Ανάλυση Σφαλμάτων: Alert Fatigue.....31
4.3 Χρονική Μοντελοποίηση (Time-Based modeling): Δίκτυα Botnet και επιθέσεις DDoS.. 32

4.3.1 Θεωρητικό Υπόβαθρο: Μοτίβα Επικοινωνίας και Περιορισμοί Μεμονωμένης Ανάλυσης..... 32
4.3.2 Σειριακή Συνάθροιση Ροών Σταθερού Πλήθους (Fixed-Count Sequential Flow Aggregation)..... 33
4.3.3 Πειραματική Αξιολόγηση και Οπτικοποίηση..... 34
4.4 Deep learning στην Ανάλυση Δικτυακής Κίνησης..... 35
4.4.1 Αρχιτεκτονική Μοντέλου MLP..... 35
Κεφάλαιο 5: Επιχειρησιακή Αξιολόγηση και Επεξηγηματικότητα..... 38
5.1 Επιχειρησιακη αξιολόγηση σε ρεαλιστικές συνθήκες..... 38
5.1.1 Πίνακας Σύγχυσης (Confusion Matrix)..... 38
5.2 Επεξηγηματικότητα και Διαφάνεια Αποφάσεων (Explainable AI)..... 41
5.2.1 Τεχνική Υλοποίηση SHAP και Προκλήσεις..... 42
5.3 Επιθέσεις Αποφυγής και Ευπάθεια..... 47
Κεφάλαιο 6: Συμπεράσματα και Επιχειρησιακή Ενσωμάτωση..... 49
6.1 Το Χάσμα μεταξύ Academic και Πραγματικού Περιβάλλοντος Προσαρμογής..... 49
6.2 Deployment Note..... 49
6.3 Διαχείριση Κύκλου Ζωής και Ανατροφοδότηση (MLOps & Feedback Loop)..... 52
Κεφάλαιο 7: Εγχειρίδιο αναπαραγωγιμότητας και Λογισμικό..... 53
7.1 Απαιτήσεις Λογισμικού (Software Prerequisites)..... 53
7.2 Λήψη, δομή δεδομένων και cross platform λειτουργικότητα..... 54
Βιβλιογραφία..... 56

Κεφάλαιο 1: Εισαγωγή

Η διαρκής εξέλιξη των πολυμορφικών κακόβουλων λογισμικών και η αύξηση των Προηγμένων Επίμονων Απειλών, καθιστούν τις παραδοσιακές μεθόδους ασφαλείας, όπως τα συστήματα ανίχνευσης βάσει υπογραφών (κοινώς antivirus) και τα τείχη προστασίας, συχνά ανεπαρκείς. Το γεγονός αυτό επιβάλλει τη μετάβαση σε μια πιο δυναμική και προληπτική προσέγγιση. Η Ανάλυση Δικτυακής Κίνησης (Network Traffic Analysis εφεξής NTA) αποτελεί τον ακρογωνιαίο λίθο αυτής της μετάβασης, δίνοντας πλήρη ορατότητα στη συμπεριφορά των δεδομένων που διακινούνται σε ένα δίκτυο.

Οι κύριες περιπτώσεις χρήσης της NTA στην σύγχρονη Κυβερνοάμυνα περιλαμβάνουν:

- **Εντοπισμό Εισβολών:** Η μετάβαση από τον εντοπισμό γνωστών απειλών στην αναγνώριση στατιστικών ανωμαλιών επιτρέπει τον εντοπισμό επιθέσεων Zero-Day.
- **Ανάλυση Επικοινωνιών Malware & Botnets:** Αναγνώριση κρυπτογραφημένης ή συγκεκαλυμμένης επικοινωνίας μολυσμένων συστημάτων με εξυπηρετητές διοίκησης και ελέγχου, μέσω ανάλυσης μοτίβων (π.χ. συχνότητα beaconing, περιοδικότητα, μέγεθος πακέτων).
- **Ανίχνευση DDoS Επιθέσεων:** έγκαιρη αναγνώριση επιθέσεων όγκου ή επιθέσεων σε επίπεδο πρωτοκόλλου προτού προκαλέσουν άρνηση εξυπηρέτησης.

- **Εντοπισμός Εσωτερικών Απειλών:** Συνεχής παρακολούθηση για μη εξουσιοδοτημένη μαζική εξαγωγή δεδομένων.

Μία από τις μεγαλύτερες προκλήσεις στην εφαρμογή της Μηχανικής Μάθησης στον τομέα της NTA είναι το χάσμα μεταξύ της θεωρητικής απόδοσης και της πρακτικής επιχειρησιακής εφαρμογής. Στη διεθνή βιβλιογραφία, μια πληθώρα από μοντέλα παρουσιάζουν εξαιρετικά υψηλά ποσοστά ακρίβειας, ωστόσο, κατά την ανάπτυξή τους σε πραγματικά περιβάλλοντα, συχνά παράγουν υπερβολικό αριθμό από False Positives πράγμα που οδηγεί στο φαινόμενο του alert fatigue, με αποτέλεσμα πολλοί αναλυτές να αγνοούν κρίσιμες ειδοποιήσεις (με την υπόθεση ότι το σύστημα έχει βγάλει εσφαλμένο θετικό κίνδυνο). Συνεπώς πρωταρχικός στόχος ενός μοντέλου ML δεν είναι απλώς η ακαδημαϊκή ακρίβεια, αλλά και η λειτουργική στιβαρότητα και η ενίσχυση της ικανότητας των αναλυτών να φιλτράρουν τον "θόρυβο" από τις πραγματικές απειλές.

Εν κατακλείδι, η ενσωμάτωση της Μηχανικής Μάθησης στην Ανάλυση Δικτυακής Κίνησης κρίνεται πλέον αναγκαία. Αξιοποιώντας προηγμένους αλγορίθμους για την εξαγωγή χαρακτηριστικών από τεράστιους όγκους δεδομένων, η NTA μετατρέπει το

δίκτυο σε έναν ενεργό αισθητήρα ασφαλείας, ικανό να εντοπίζει πολύπλοκες επιθέσεις που διαφεύγουν από τα συμβατικά συστήματα.

Κεφάλαιο 2: Υπόβαθρο και Μεθοδολογία

2.1 Σύντομη Βιβλιογραφική Ανασκόπηση

Η ανάλυση της δικτυακής κίνησης μέσω τεχνικών Μηχανικής Μάθησης αποτελεί έναν ραγδαία αναπτυσσόμενο τομέα. Ιδιαίτερα σημαντική υπήρξε η συνεισφορά συνόλων δεδομένων αναφοράς που αποτυπώνουν ρεαλιστικές συνθήκες. Στη διεθνή βιβλιογραφία, η δημιουργία του συνόλου δεδομένων CIC-IDS2017 (Sharafaldin et al., 2018) επέτρεψε την αξιολόγηση αλγορίθμων σε μοντέρνα πρωτόκολλα και επιθέσεις. Έκτοτε πολλές μελέτες αξιοποιούν δενδρικούς αλγορίθμους και νευρωνικά δίκτυα για την ταξινόμηση αυτής της κίνησης, αναδεικνύοντας τη σημασία της ορθής εξαγωγής χαρακτηριστικών [11].

2.2 Μετάβαση από Παρατηρήσεις Επιπέδου Πακέτου (Packet-Level) σε Επίπεδο Ροής (Flow-Level)

Το πακέτο αποτελεί τη βασική μονάδα μετάδοσης πληροφορίας. Παρότι η ανάλυση σε αυτό το επίπεδο προσφέρει την υψηλότερη δυνατή λεπτομέρεια, αποδεικνύεται υπολογιστικά εξαιρετικά δαπανηρή και συχνά αδύνατη σε περιπτώσεις όπου το φορτίο είναι κρυπτογραφημένο.

Για την αποτελεσματική εκπαίδευση μοντέλων Μηχανικής Μάθησης, η ανάλυση επικεντρώνεται στις Δικτυακές Ροές. Ως “ροή” ορίζεται μια ακολουθία πακέτων που διαμοιράζονται κοινά χαρακτηριστικά -συνήθως την πεντάδα: IP Πηγής, IP Προορισμού, Θύρα Πηγής, Θύρα Προορισμού και Πρωτόκολλο- εντός ενός συγκεκριμένου χρονικού παραθύρου. Η προσέγγιση αυτή παρέχει metadata επικοινωνίας, μειώνοντας δραματικά τον όγκο των δεδομένων, ενώ διατηρεί την ικανότητα ανίχνευσης ανωμαλιών, ακόμη και σε πλήρως κρυπτογραφημένη κίνηση.

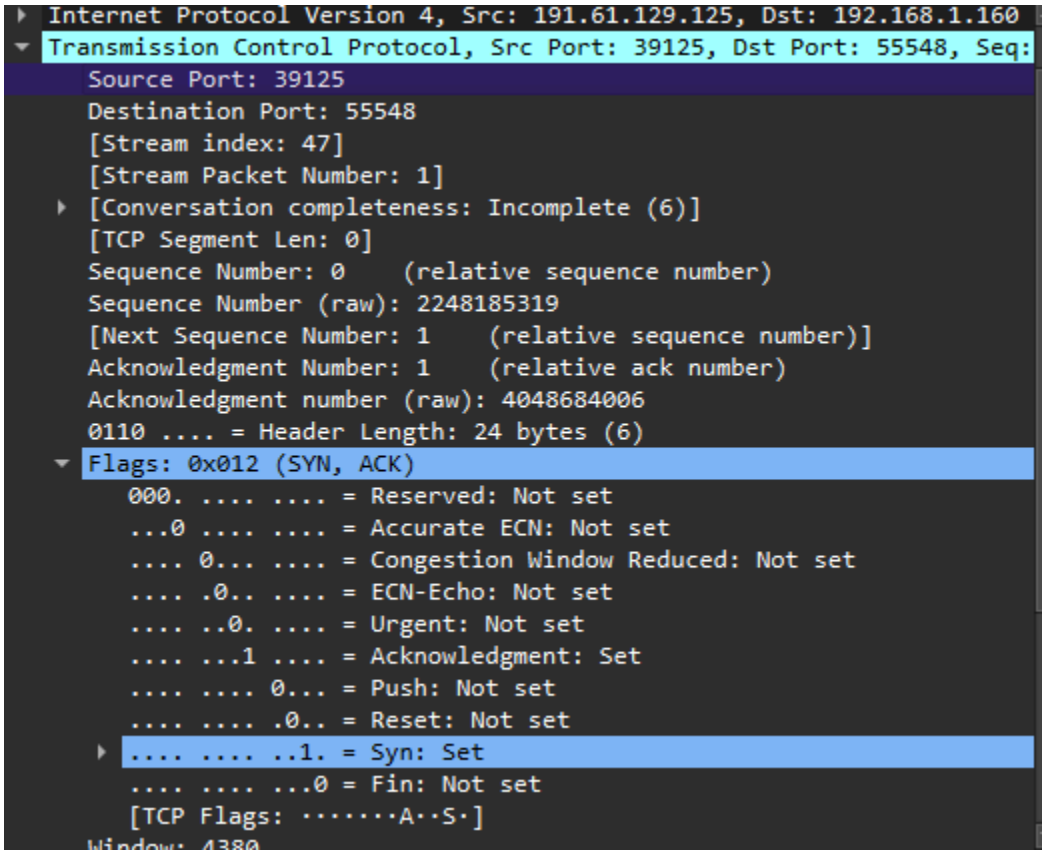
2.3 Εξαγωγή Στατιστικών Χαρακτηριστικών (Feature Extraction)

Κατά την παρατήρηση ενός αρχείου καταγραφής (PCAP) στο Wireshark, εντοπίζουμε μεμονωμένα γεγονότα. Για να δεχτεί ένα μοντέλο ML τα δεδομένα αυτά για την

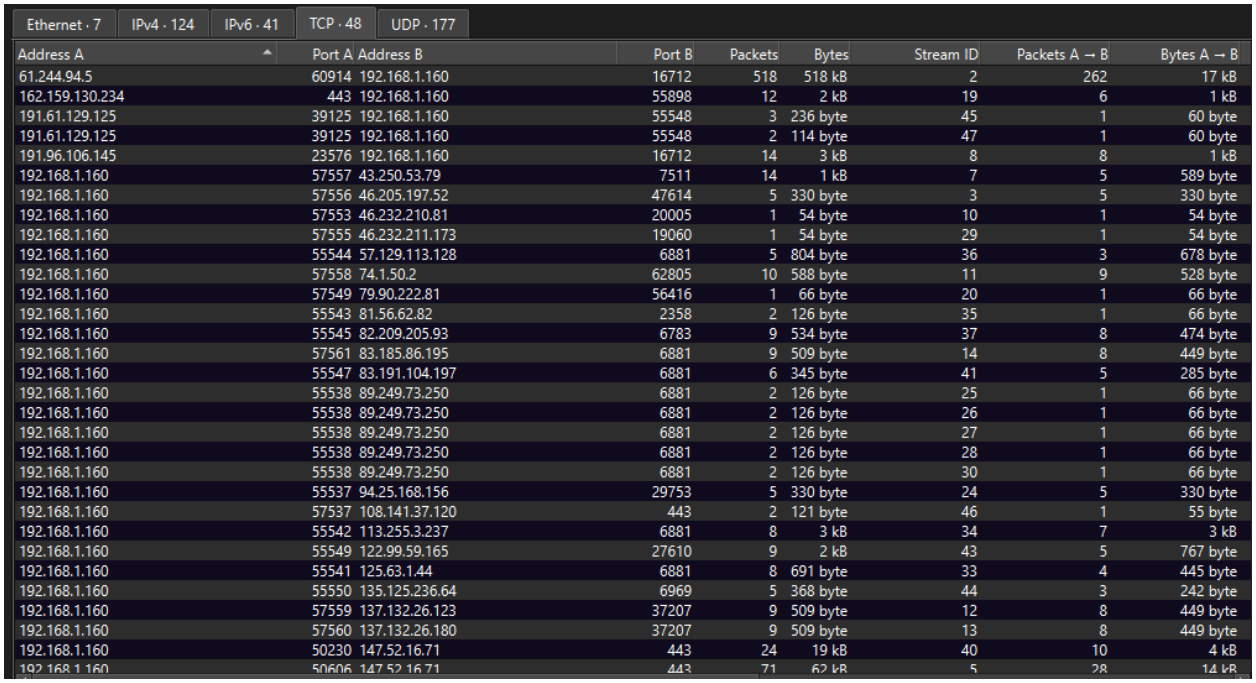
εκπαίδευσή του (όπως θα γίνει και στα επόμενα στάδια της έρευνας), πρέπει να μετατραπούν αυτά τα γεγονότα σε στατιστικά χαρακτηριστικά ή αλλιώς features. Παρακάτω αναλύονται ορισμένα σημαντικά χαρακτηριστικά που προκύπτουν από τη μελέτη και τη διαδικασία αυτή:

- **Χρονική Διάρκεια και Χρόνοι Άφιξης:** Παρέχουν ενδείξεις για τη φύση της επικοινωνίας. Για Παράδειγμα μια εξαιρετικά χαμηλή διακύμανση στον χρόνο άφιξης πακέτων συχνά υποδεικνύει αυτοματοποιημένη δραστηριότητα (π.χ. botnet), σε αντίθεση με την ασύμμετρη φύση της ανθρώπινης διάδρασης.
- **Στατιστικά Μεγέθους Πακέτων:** Παράμετροι όπως η Ελάχιστη, Μέγιστη, Μέση Τιμή και Τυπική Απόκλιση επιτρέπουν τον διαχωρισμό απλών πακέτων ελέγχου (την control traffic) από συμβάντα μαζικής εξαγωγής δεδομένων.
- **Καταμέτρηση Σημαιών**: Η καταμέτρηση των TCP Flags λειτουργεί ως άμεσος δείκτης μιας DDoS επίθεσης, όπου παρατηρείται απότομη ασυμμετρία στις συνδέσεις

Η παρακάτω ανάλυση δικτυακής κίνησης πραγματοποιήθηκε μέσω του λογισμικού Wireshark προς επιβεβαίωση των παραπάνω εννοιών.



Σχήμα 2.1: Ανάλυση πακέτου σε επίπεδο μεταφοράς (TCP) μέσω Wireshark. Παρατηρούνται τα ενεργοποιημένα flags (SYN, ACK) κατά την εγκαθίδρυση της σύνδεσης, αντιπροσωπεύοντας την ακατέργαστη, μη ομαδοποιημένη πληροφορία.



Ethernet · 7 | IPv4 · 124 | IPv6 · 41 | TCP · 48 | UDP · 177

Address A	Port A	Address B	Port B	Packets	Bytes	Stream ID	Packets A → B	Bytes A → B
61.244.94.5	60914	192.168.1.160	16712	518	518 kB	2	262	17 kB
162.159.130.234	443	192.168.1.160	55898	12	2 kB	19	6	1 kB
191.61.129.125	39125	192.168.1.160	55548	3	236 byte	45	1	60 byte
191.61.129.125	39125	192.168.1.160	55548	2	114 byte	47	1	60 byte
191.96.106.145	23576	192.168.1.160	16712	14	3 kB	8	8	1 kB
192.168.1.160	57557	43.250.53.79	7511	14	1 kB	7	5	589 byte
192.168.1.160	57556	46.205.197.52	47614	5	330 byte	3	5	330 byte
192.168.1.160	57553	46.232.210.81	20005	1	54 byte	10	1	54 byte
192.168.1.160	57555	46.232.211.173	19060	1	54 byte	29	1	54 byte
192.168.1.160	55544	57.129.113.128	6881	5	804 byte	36	3	678 byte
192.168.1.160	57558	74.1.50.2	62805	10	588 byte	11	9	528 byte
192.168.1.160	57549	79.90.222.81	56416	1	66 byte	20	1	66 byte
192.168.1.160	55543	81.56.62.82	2358	2	126 byte	35	1	66 byte
192.168.1.160	55545	82.209.205.93	6783	9	534 byte	37	8	474 byte
192.168.1.160	57561	83.185.86.195	6881	9	509 byte	14	8	449 byte
192.168.1.160	55547	83.191.104.197	6881	6	345 byte	41	5	285 byte
192.168.1.160	55538	89.249.73.250	6881	2	126 byte	25	1	66 byte
192.168.1.160	55538	89.249.73.250	6881	2	126 byte	26	1	66 byte
192.168.1.160	55538	89.249.73.250	6881	2	126 byte	27	1	66 byte
192.168.1.160	55538	89.249.73.250	6881	2	126 byte	28	1	66 byte
192.168.1.160	55538	89.249.73.250	6881	2	126 byte	30	1	66 byte
192.168.1.160	55537	94.25.168.156	29753	5	330 byte	24	5	330 byte
192.168.1.160	57537	108.141.37.120	443	2	121 byte	46	1	55 byte
192.168.1.160	55542	113.255.3.237	6881	8	3 kB	34	7	3 kB
192.168.1.160	55549	122.99.59.165	27610	9	2 kB	43	5	767 byte
192.168.1.160	55541	125.63.1.44	6881	8	691 byte	33	4	445 byte
192.168.1.160	55550	135.125.236.64	6969	5	368 byte	44	3	242 byte
192.168.1.160	57559	137.132.26.123	37207	9	509 byte	12	8	449 byte
192.168.1.160	57560	137.132.26.180	37207	9	509 byte	13	8	449 byte
192.168.1.160	50230	147.52.16.71	443	24	19 kB	40	10	4 kB
192.168.1.160	50606	147.52.16.71	443	71	62 kB	5	28	14 kB

Σχήμα 2.2: Αποτύπωση της μετάβασης στη λογική των Δικτυακών Ροών (Flows). Ομαδοποίηση πακέτων βάσει διευθύνσεων IP και Θυρών (Ports).

Στο Σχήμα 2.2 αποτυπώνεται η μετάβαση στη λογική των ροών. Πολλά μεμονωμένα πακέτα ομαδοποιούνται σε μια ενιαία καταγραφή βάσει των IP και των Ports, επιτρέποντας την εξαγωγή των χαρακτηριστικών που προαναφέρθηκαν, όπως ο συνολικός αριθμός πακέτων και ο συνολικός όγκος δεδομένων (σε Bytes) ανά κατεύθυνση.

2.4 Μεθοδολογία και Εργαλεία

Για τη μαζική μετάβαση από το PCAP στο επίπεδο δομημένων ροών (π.χ. μορφή CSV ή Dataframe) που απαιτείται για την εκπαίδευση των μοντέλων, δεν χρησιμοποιείται το περιβάλλον διεπαφής του Wireshark. Αντίθετα, αξιοποιούνται εξειδικευμένα εργαλεία εξαγωγής ροών (flow extractors/meters) όπως το CICFlowMeter ή το Zeek. Αυτά τα εργαλεία αναλαμβάνουν τον αυτόματο υπολογισμό των features και την παραγωγή συνόλων δεδομένων, προετοιμάζοντας το έδαφος για την ανάλυση με βιβλιοθήκες της Python όπως το pandas.

2.5 Προκλήσεις και Στρατηγική Προεπεξεργασίας Δεδομένων (Preprocessing Pipeline)

Κατα την αναζήτηση του κατάλληλου dataset και έπειτα απο καθοδήγηση του επιβλέποντος καθηγητή, η τελική αξιολόγηση επικεντρώθηκε στα CIC-IDS 2017 και NSL-KDD, επιλέγοντας τελικά το πρώτο, μια και ενσωματώνει πιο σύγχρονα πρωτόκολλα επικοινωνίας, κάνοντας το πιο αξιόπιστο εργαλείο για την εξαγωγή συμπερασμάτων συναρτηση με τα σημερινά δίκτυα. Προκειμένου να καταστούν τα δεδομένα κατάλληλα για την εκπαίδευση των αλγορίθμων Μηχανικής Μάθησης, απαιτήθηκε μια σειρά από στοχευμένους μετασχηματισμούς και καθαρισμούς.

2.5.1 Συντακτικός Καθαρισμός και Δομικές Ασυνέπειες

Ξεκινώντας τη φόρτωση και ανάλυση του dataset, το πρώτο εμπόδιο που εντοπίστηκε αφορούσε δομικές και συντακτικές ασυνέπειες στα μεταδεδομένα του αρχείου. Πιο συγκεκριμένα, παρατηρήθηκε το σύνηθες, πλην όμως προβληματικό, φαινόμενο της ύπαρξης περιττών κενών χαρακτήρων (whitespace) στις ονομασίες των στηλών (με τα features). Η ύπαρξη τέτοιων χαρακτήρων στην αρχή ή στο τέλος των ονομάτων των μεταβλητών προκαλεί σοβαρά σφάλματα κατά την κλήση τους μέσω προγραμματιστικών βιβλιοθηκών όπως το Pandas στην Python. Για την αποφυγή τέτοιων σφαλμάτων κατά την αυτοματοποιημένη ανάλυση, εφαρμόστηκε μαζικός συντακτικός καθαρισμός σε όλες τις επικεφαλίδες του συνόλου δεδομένων, διασφαλίζοντας την ομοιομορφία της δομής.

2.5.2 Διαχείριση Ακραίων Τιμών (Infinity) και Ελλειπουσών Εγγραφών (NaN)

Πέραν των τυπογραφικών ασυνεπειών, εντοπίστηκε μια σημαντική τεχνική ιδιαιτερότητα κατά την εξαγωγή των δεδομένων: ένας αξιοσημείωτος αριθμός εγγραφών παρουσίαζε την τιμή του απείρου (Infinity) ή απουσίαζε παντελώς η καταγραφή της τιμής (Not a Number - NaN) σε συγκεκριμένα χαρακτηριστικά.
Αναλύοντας τη ρίζα του προβλήματος, διαπιστώθηκε ότι αυτό αποτελεί μια απολύτως λογική και αναμενόμενη συμπεριφορά, αν αναλογιστούμε τον τρόπο με τον οποίο λειτουργεί το λογισμικό εξαγωγής ροών (CICFlowMeter) που χρησιμοποιήθηκε για την παραγωγή του dataset. Το εργαλείο αυτό υπολογίζει στατιστικά χαρακτηριστικά που βασίζονται σε ρυθμούς μετάδοσης, όπως για παράδειγμα ο αριθμός πακέτων ανά

δευτερόλεπτο ή ο όγκος των μεταδιδόμενων δεδομένων (Bytes/s). Ο μαθηματικός τύπος για αυτούς τους υπολογισμούς απαιτεί τη διαίρεση του πλήθους με τη συνολική χρονική διάρκεια της ροής.

Σε περιπτώσεις όπου μια διαδικτυακή ροή δημιουργείται και τερματίζεται σε απειροελάχιστο χρονικό διάστημα, η χρονική διάρκεια της ροής προσεγγίζει μαθηματικά το μηδέν. Κατά συνέπεια, ο υπολογισμός του ρυθμού μετάδοσης οδηγεί σε διαίρεση με το μηδέν, γεγονός που αναγκάζει το λογισμικό να καταγράψει το αποτέλεσμα ως Άπειρο.

Οι αλγόριθμοι Μηχανικής Μάθησης, ωστόσο, βασίζονται αποκλειστικά σε πράξεις γραμμικής άλγεβρας και υπολογισμούς σε matrices. Ως εκ τούτου, δεν μπορούν να επεξεργαστούν τιμές που δεν ανήκουν στο σύνολο των πραγματικών αριθμών, άρα για την αντιμετώπιση αυτού του προβλήματος, εφαρμόστηκε μια στρατηγική δύο βημάτων:

1. Αρχικά, εντοπίστηκαν όλες οι τιμές απείρου στο σύνολο δεδομένων και μετατράπηκαν προγραμματιστικά σε Not-a-Number τιμές (NaN).
2. Και στη συνέχεια, εφαρμόστηκε ολική διαγραφή όλων των δειγμάτων που περιείχαν έστω και μία τιμή NaN.

Η προσέγγιση αυτή -δηλαδή η πλήρης αφαίρεση των εγγραφών αντί της αντικατάστασής τους με κάποια μέση τιμή- κρίνεται επιστημονικά ασφαλής και επιβεβλημένη μια και τα αλλοιωμένα αυτά δείγματα αντιπροσωπεύουν ένα ελάχιστο ποσοστό του συνολικού όγκου δεδομένων, αγγίζοντας μόλις το ~0,1% των εκατομμυρίων διαθέσιμων ροών. Επομένως η εξάλειψή τους δεν αλλοιώνει τη στατιστική κατανομή των κλάσεων και μας διασφαλίζει ότι το σύνολο εκπαίδευσης αποτελείται αποκλειστικά από robust και μαθηματικά υπολογίσιμα δεδομένα, αποτρέποντας μελλοντικές αστοχίες κατά το στάδιο της βελτιστοποίησης των μοντέλων.

```
Loading files from dataset
C:\Users\Konst\AppData\Local\Temp\ipykernel_16020\449216163.py:9: DtypeWarning: Columns (0,1,3,6,84) have mixed types. Specify dtype option on import or set low_memory=False.
  data4 = pd.read_csv(r'.\TrafficLabelling\Thursday-WorkingHours-Morning-WebAttacks.pcap_ISCX.csv', encoding='latin1')
Combining Datasets...                                                    # το Warning εδω δεν μας πειράζει μια και θα διορθωθεί παρακάτω στο preprocessing
Dimensions after Union:  (3119345, 85)
Removing Duplicates...
New Dimensions without duplicates:  (2830541, 85)
Cleanup of weird values (Infinity και NaN)...
D after cleanup: (2827677, 85)
Removed Leakage Columns ['Source IP', 'Destination IP', 'Source Port', 'Timestamp']

Loading and Cleanup of dataset Complete!
Label
BENIGN                        2271122
DoS Hulk                       230123
PortScan                       158804
DDoS                           128025
DoS GoldenEye                   10293
FTP-Patator                      7935
SSH-Patator                      5897
DoS slowloris                    5796
DoS Slowhttptest                 5499
Bot                              1956
Web Attack – Brute Force         1507
Web Attack – XSS                  652
Infiltration                       36
Web Attack – Sql Injection         21
Heartbleed                         11
Name: count, dtype: int64
```

Σχήμα 2.3 Διαδικασία Ενοποίησης, εκκαθάρισης και κωδικοποίησης (με label encoding) του συνόλου δεδομένων CIC-IDS2017. Το warning εδώ δεν μας επηρεάζει μια και θα διορθωθεί παρακάτω στο preprocessing

Dimensions after Combining All separate files: (3119345, 85)
New Dimensions without duplicates: (2830541, 85)
Dimensions after cleanup: (2827677, 85)

Loading and Cleanup of dataset Complete!
Label
BENIGN 2271122
DoS Hulk 230123
PortScan 158804
DDoS 128025
DoS GoldenEye 10293
FTP-Patator 7935
SSH-Patator 5897
DoS slowloris 5796
DoS Slowhttptest 5499
Bot 1956
Web Attack – Brute Force 1507
Web Attack – XSS 652
Infiltration 36
Web Attack – Sql Injection 21
Heartbleed 11

Σχήμα 2.4: Output του pre-processing κώδικα επιδεικνύοντας συνολικά μεγέθη του dataset και τον αριθμό των επιθέσεων που περιέχει

2.5.3 Αξιολόγηση Ταξικής Ανισορροπίας:

Κατά την ανάλυση των ετικετών του συνόλου δεδομένων, όπως αποτυπώνεται στο Σχήμα 2.4, παρατηρήθηκε το φαινόμενο της ακραίας ταξικής ανισορροπίας, το οποίο αποτελεί τυπικό χαρακτηριστικό των πραγματικών δεδομένων κυβερνοασφάλειας. Η συντριπτική πλειονότητα του δείγματος αφορά κανονική κίνηση. Παράλληλα, εντοπίζονται σημαντικές διαφοροποιήσεις ως προς τον όγκο μεταξύ των διαφόρων τύπων επιθέσεων.

Για παράδειγμα, οι επιθέσεις όγκου (όπως τα DoS και τα PortScans) καταγράφουν εκατοντάδες χιλιάδες ροές, καθώς η φύση τους βασίζεται στην εξάντληση του διαθέσιμου bandwidth μέσω μαζικής αποστολής δεδομένων, συχνά αξιοποιώντας δίκτυα μολυσμένων υπολογιστών (botnets). Αντίθετα, οι στοχευμένες επιθέσεις (όπως το SQL Injection ή το Infiltration) αντιπροσωπεύονται από ελάχιστες δεκάδες καταγραφές. Αυτό είναι απόλυτα φυσιολογικό και ρεαλιστικό: τέτοιου είδους επιθέσεις έπονται εκτενούς αναγνώρισης και αποσκοπούν, για παράδειγμα, στην παραπλάνηση ενός υπαλλήλου ώστε να εκτελέσει ένα κακόβουλο αρχείο, παράγοντας την ελάχιστη δυνατή δικτυακή δραστηριότητα για να αποφύγουν τον εντοπισμό.

2.5.4 Αποφυγή Διαρροής Πληροφορίας και Κανονικοποίηση

Ένα καθοριστικό βήμα πριν την τελική προετοιμασία των δεδομένων αποτέλεσε η αποτροπή του φαινομένου του data leakage. Προκειμένου να διασφαλιστεί ότι τα μοντέλα δεν θα “αποστηθίσουν” απλώς συγκεκριμένες διευθύνσεις IP ή αναγνωριστικά (Flow IDs), αλλά αντίθετα θα εκπαιδευτούν στα πραγματικά μοτίβα της συμπεριφοράς, τα εν λόγω αναγνωριστικά μεταδεδομένα αφαιρέθηκαν ρητά. Η εκπαίδευση βασίστηκε αυστηρά σε 79 αριθμητικές μεταβλητές.

Ωστόσο, οι μεταβλητές αυτές παρουσιάζουν τεράστιες αποκλίσεις ως προς την κλίμακά τους (π.χ. η διάρκεια μιας ροής μετριέται σε εκατομμύρια, ενώ ο αριθμός των πακέτων αποτελείται από μονοψήφιους αριθμούς). Για την αντιμετώπιση αυτού του ζητήματος εφαρμόστηκε κανονικοποίηση (normalization/scaling) με τη χρήση της συνάρτησης StandardScaler. Μέσω αυτής της μεθόδου, τα δεδομένα προβάλλονται σε μια κοινή κλίμακα, αποτρέποντας την εσφαλμένη σύγκλιση των μαθηματικών αλγορίθμων που υπολογίζουν αποστάσεις. Παράλληλα, υλοποιήθηκε κωδικοποίηση των ετικετών προκειμένου οι κατηγορίες των επιθέσεων να μετασχηματιστούν από μορφή κειμένου σε αριθμητικές τιμές, διευκολύνοντας την περαιτέρω αλγοριθμική επεξεργασία.

Για την πλήρη αποτροπή στατιστικής διαρροής πληροφορίας από το σύνολο δοκιμής, ο υπολογισμός των παραμέτρων κανονικοποίησης (μ, σ) μέσω της μεθόδου fit transform

του Standard Scaler εφαρμόστηκε αποκλειστικά στο σύνολο εκπαίδευσης X_train μετά τον διαχωρισμό των δεδομένων, ενώ στο σύνολο δοκιμής X_test εφαρμόστηκε αυστηρά ο μετασχηματισμός transform με τις παραμέτρους της εκπαίδευσης.

2.5.5 Χρονικά Ενήμερος Διαχωρισμός (Time-Aware Splitting)

Η ολοκλήρωση της προεπεξεργασίας απαιτούσε τον διαχωρισμό του συνόλου δεδομένων σε υποσύνολα εκπαίδευσης (train set) και δοκιμής (test set). Απορρίφθηκε η συνήθης προσέγγιση του τυχαίου διαχωρισμού (random splitting), καθώς αυτή θα παραβίαζε τη χρονική αλληλουχία των πακέτων, επιτρέποντας στο μοντέλο να εκπαιδευτεί με μελλοντικά δεδομένα.

Αντίθετα, υιοθετήθηκε η στρατηγική του time-aware splitting όπου διατηρώντας τα δεδομένα στην αρχική τους χρονική σειρά, δεσμεύτηκε το πρώτο 80% (περίπου 2,2 εκατομμύρια εγγραφές) για την εκπαίδευση και το εναπομείναν 20% (περίπου 565.000 εγγραφές) για τη δοκιμή. Η συγκεκριμένη αρχιτεκτονική προσομοιώνει με ακρίβεια τις πραγματικές συνθήκες λειτουργίας ενός Κέντρου Επιχειρήσεων Ασφάλειας, όπου το αμυντικό σύστημα εκπαιδεύεται αξιοποιώντας ιστορικά δεδομένα του παρελθόντος, με αποκλειστικό σκοπό την ανίχνευση αναδυόμενων και άγνωστων επιθέσεων στο μέλλον.

Σημειώνεται ότι στο Κεφάλαιο 4, πέραν του χρονικού διαχωρισμού (Πρωτόκολλο Α: Αξιολόγηση Χρονικής Γενίκευσης), εξετάζεται συμπληρωματικά και ένα δεύτερο πρωτόκολλο τυχαίου διαχωρισμού (Πρωτόκολλο Β: Closed-World Shuffled Baseline) αποκλειστικά και μόνο για τη δίκαιη αλγοριθμική σύγκριση επί γνωστών κατανομών.

```
Final Preprocessing Stage
  We have 79 X Characteristics
Performing Label Encoding (Y)...

Classes:
  BENIGN: 0
  Bot: 1
  DDoS: 2
  DoS GoldenEye: 3
  DoS Hulk: 4
  DoS Slowhttptest: 5
  DoS slowloris: 6
  FTP-Patator: 7
  Heartbleed: 8
  Infiltration: 9
  PortScan: 10
  SSH-Patator: 11
  Web Attack  Brute Force: 12
  Web Attack  Sql Injection: 13
  Web Attack  XSS: 14

Time Aware splitting here:
  Training set: 2262141 regs (80%)
  Testing set: 565536 regs (20%)

Applying StandardScaler (fit on X_train only, transform on X_test)...

Traffic Dataset Preprocessing Pipeline Done!
```

Σχήμα 2.5: Έξοδος διαδικασίας προεπεξεργασίας και χρονικού διαχωρισμού των δεδομένων

Κεφάλαιο 3: Ανάλυση, Επιλογή Χαρακτηριστικών και Διερευνητική Οπτικοποίηση

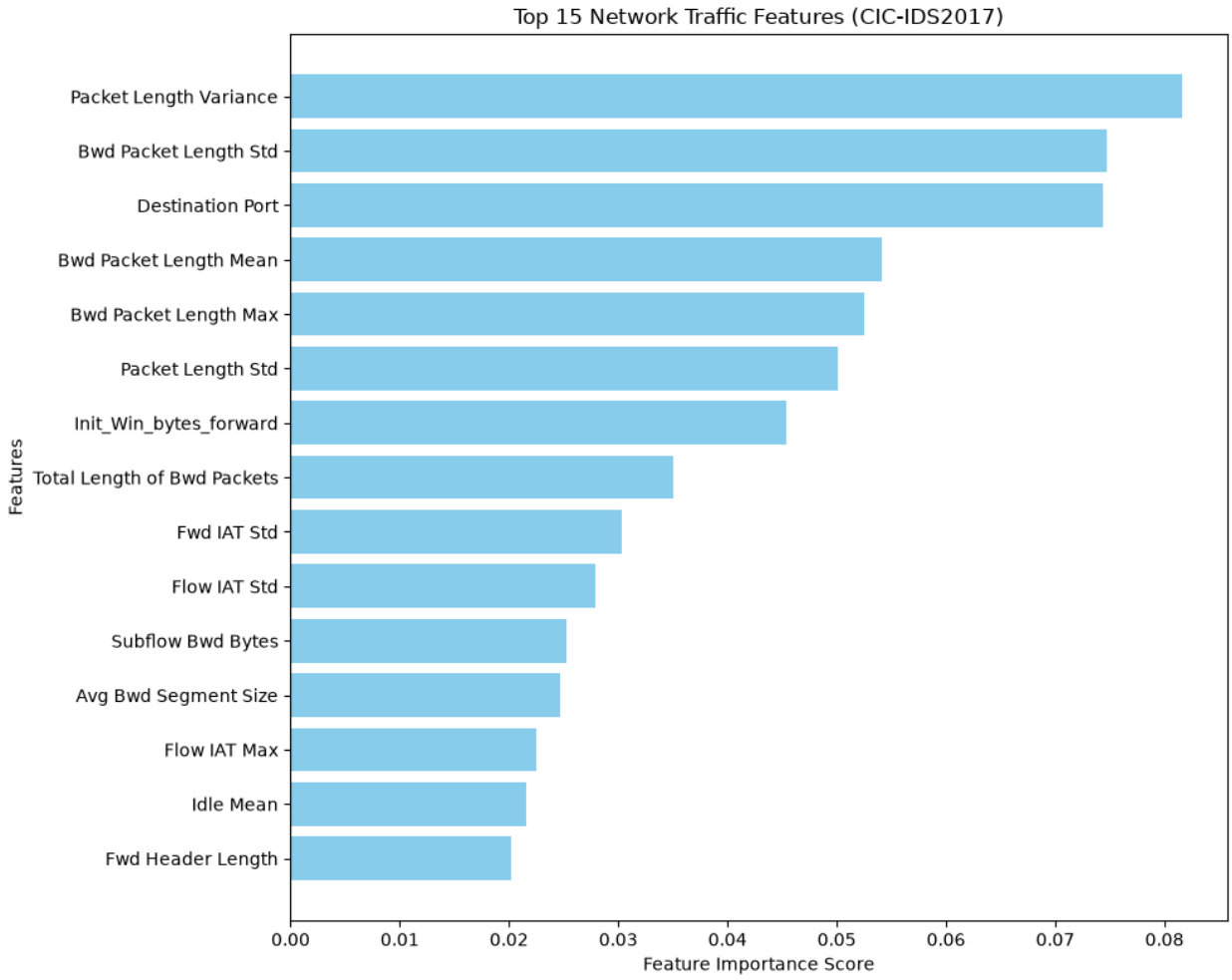
3.1 Η "Κατάρα της Dimensionality"

Μετά την ολοκλήρωση της προεπεξεργασίας, το σύνολο δεδομένων αποτελούνταν από 79 ανεξάρτητες μεταβλητές του αντιπροσώπευαν τα features. Η εκπαίδευση μοντέλων Μηχανικής Μάθησης σε δεδομένα τόσο υψηλής διαστατικότητας οδηγεί συχνά στο φαινόμενο που είναι γνωστό ως "Κατάρα της Διαστατικότητας" (εφεξής αναφερόμενο ώς Curse of Dimensionality). Η εισαγωγή περιττών ή ισχυρά συσχετισμένων μεταβλητών όχι μόνο αυξάνει εκθετικά το υπολογιστικό κόστος και τον χρόνο εκπαίδευσης, αλλά συχνά υποβαθμίζει την ικανότητα γενίκευσης του μοντέλου, εισάγοντας "θόρυβο". Ως εκ τούτου, κρίθηκε αναγκαία η εφαρμογή τεχνικών επιλογής χαρακτηριστικών. [2]

3.2 Επιλογή Χαρακτηριστικών μέσω Αλγορίθμου Τυχαίου Δάσους (Random Forest)

Για τον εντοπισμό των πλέον καθοριστικών μεταβλητών, επιλέχθηκε η χρήση του αλγορίθμου Random Forest Classifier μια επιλογή που δεν έγινε τυχαία. Τα μοντέλα που βασίζονται σε σύνολα δέντρων ενσωματώνουν εγγενείς μηχανισμούς αξιολόγησης της σημασίας των χαρακτηριστικών υπολογίζοντας τη μέση μείωση της ακαθαρσίας (ορολογιακά λέγεται Mean Decrease in Impurity - Gini Importance) σε όλους τους κόμβους του δάσους ενώ επιπλέον, παρουσιάζουν εξαιρετική ανθεκτικότητα σε δεδομένα με μη-γραμμικές συσχετίσεις.

Το μοντέλο εκπαιδεύτηκε (με 50 estimators) στο σύνολο του training set, διασφαλίζοντας την έκθεσή του σε όλες τις κλάσεις, συμπεριλαμβανομένων των εξαιρετικά σπάνιων επιθέσεων (π.χ. Heartbleed). Βάσει της βαθμολογίας βαρύτητας, απομονώθηκαν τα 15 κορυφαία χαρακτηριστικά, μειώνοντας δραστικά τον όγκο της πληροφορίας (από 79 σε 15 διαστάσεις) χωρίς να θυσιαστεί η διακριτική ικανότητα του συστήματος.



Σχήμα 3.1: Απεικόνιση των 15 σημαντικότερων δικτυακών μεταβλητών βάσει του κριτηρίου Gini Impurity του αλγορίθμου Random Forest.

```
--- Top 15 Features ---
                        Feature  Importance
43       Packet Length Variance    0.081673
14        Bwd Packet Length Std    0.074683
0              Destination Port    0.074414
13       Bwd Packet Length Mean    0.054076
11        Bwd Packet Length Max    0.052559
42            Packet Length Std    0.050157
67       Init_Win_bytes_forward    0.045402
6   Total Length of Bwd Packets    0.034993
23                  Fwd IAT Std    0.030292
18                 Flow IAT Std    0.027929
66            Subflow Bwd Bytes    0.025210
55         Avg Bwd Segment Size    0.024684
19                 Flow IAT Max    0.022467
75                    Idle Mean    0.021556
35            Fwd Header Length    0.020210
```

Σχήμα 3.2: Απεικόνιση των φαινομένων συχνότητας των 15 σημαντικότερων δικτυακών μεταβλητών καθως και το Importance τους σε αριθμητική μορφή

3.3 Ερμηνεία των Σημαντικότερων Δικτυακών Μεταβλητών

Η ανάλυση των 15 επιλεγμένων χαρακτηριστικών προσφέρει πολύτιμες επιχειρησιακές πληροφορίες σχετικά με τη συμπεριφορά των επιτιθέμενων:

- Χαρακτηριστικά Μεγέθους Πακέτου (πχ. Packet Length Variance, Bwd Packet Length Std) αποκαλύφθηκαν ως τα πλέον πιο καθοριστικά, κάτι λογικό μια και οι αυτοματοποιημένες επιθέσεις (πχ τυπου Brute Force, DDoS) παράγονται απο εξειδικευμένα scripts (πχ Nmap / Hydra) τα οποία τείνουν να στέλνουν πακέτα αυστηρά επαναλαμβανόμενου μεγέθους σε ίδιο ρυθμό, αντίθετα με την ανθρώπινη και ασύμμετρη κίνηση.

- Ακόμα, η Θύρα Προορισμού φαίνεται να είναι ένας επίσης πολύ σημαντικός δείκτης ταξινόμησης, στοιχείο που θα βοηθήσει σε εξειδικευμένες επιθέσεις με στόχο συγκεκριμένων υπηρεσιών (πχ Port 21 για FTP-Patator, Port 80/443 για Web Attacks). [1]

- Τέλος, σημαντικά αποδείχθηκαν τα Χρονικά Χαρακτηριστικά και τα Παράθυρα Ελέγχου (Flow/Fwd IAT Std, Init_Win_bytes_forward), μια και τα κακόβουλα

εργαλεία παρουσιάζουν συχνά ανωμαλίες στους χρόνους άφιξης των πακέτων με τεχνητές χρονικές σταθερές ή εκτελούν επιθέσεις υπερφόρτωσης με μηδενική καθυστέρηση (zero delay), προδίδοντας την απουσία τυπικής συμπεριφοράς ενός web browser.

Έτσι, με την εξαγωγή και διατήρηση των 15 αυτών κορυφαίων δεικτών, δημιουργήθηκαν τα τελικά βελτιστοποιημένα σύνολα εκπαίδευσης και δοκιμής, έτοιμα για την εφαρμογή αλγορίθμων supervised learning.

Για την πλήρη κατανόηση αυτών των μοτίβων, είναι κρίσιμη η ανάλυση της φύσης των επιθετικών εργαλείων που τα παράγουν. Για παράδειγμα, το λογισμικό Nmap, κατά τη διάρκεια μιας σάρωσης "Half-Open" (το SYN Scan), δεν ολοκληρώνει ποτέ την τριπλή χειραψία (μια διαδικασία στην οποία ο πελάτης ξεκινά τη συνδεση στέλνοντας ένα πακέτο με τη σημαία SYN και έναν αρχικό αριθμό ακολουθίας (χ), έπειτα ο διακομιστής απαντά με SYN και ACK, στέλνοντας τον δικό του αρχικό αριθμό ακολουθίας (y) και επιβεβαιώνει το αίτημα του πελάτη με αριθμό επιβεβαίωσης χ+1, και τέλος ο πελάτης ολοκληρώνει τη σύνδεση στέλνοντας ένα πακέτο ACK με αριθμό επιβεβαίωσης y+1 επιβεβαιώνοντας την απάντηση του διακομιστή).
Αντιθέτως αποστέλλει μαζικά πακέτα SYN και, μόλις λάβει απάντηση SYN-ACK από το θύμα, διακόπτει απότομα τη σύνδεση στέλνοντας ένα πακέτο RST (- Reset). Παράγοντας με αυτή η συμπεριφορά ροές ελάχιστης διάρκειας με σχεδόν μηδενικό όγκο δεδομένων επιστροφής.
Αντίστοιχα, εργαλεία επιθέσεων λεξικού όπως η Hydra, αυτοματοποιούν την αποστολή χιλιάδων HTTP POST requests σε ελάχιστο χρόνο. Επειδή το payload κάθε δοκιμής -δηλαδή ο συνδυασμός username και password- έχει σχεδόν σταθερό μέγεθος σε bytes, η στατιστική διακύμανση του μεγέθους των πακέτων τείνει στο μηδέν, δημιουργώντας ένα εξόφθαλμο μαθηματικό αποτύπωμα στον χώρο των χαρακτηριστικών.

3.3.1 Περιορισμοί Επιλογής Χαρακτηριστικών

Είναι σημαντικό να επισημανθεί ότι η επιλογή χαρακτηριστικών μέσω του κριτηρίου Gini Impurity του Random Forest ενέχει γνωστούς μεθοδολογικούς περιορισμούς: Αφενός τείνει να ευνοεί χαρακτηριστικά με πολλές μοναδικές τιμές, και αφετέρου η χρήση χαρακτηριστικών που επιλέχθηκαν απο δενδρικό μοντέλο ενδέχεται να προσδίδει συγκριτικό πλεονέκτημα στους δενδρικούς αλγόριθμους έναντι άλλων μοντέλων. Ειδικότερα, η υψηλή βαθμολογία της μεταβλητής Destination Port πρέπει να αντιμετωπίζεται με επιφύλαξη, καθώς σε εργαστηριακά σύνολα δεδομένων οπως το CIC-IDS2017 μπορεί να λειτουργήσει ώς τεχνητή συντόμευση επειδή συγκεκριμένες

επιθέσεις εκτελέστηκαν σε σταθερές θύρες. Για τον λόγο αυτό η συνεισφορά των 15 χαρακτηριστικών επαληθεύεται ανεξάρτητα στο Κεφάλαιο 5 μέσω της μεθόδου SHAP.

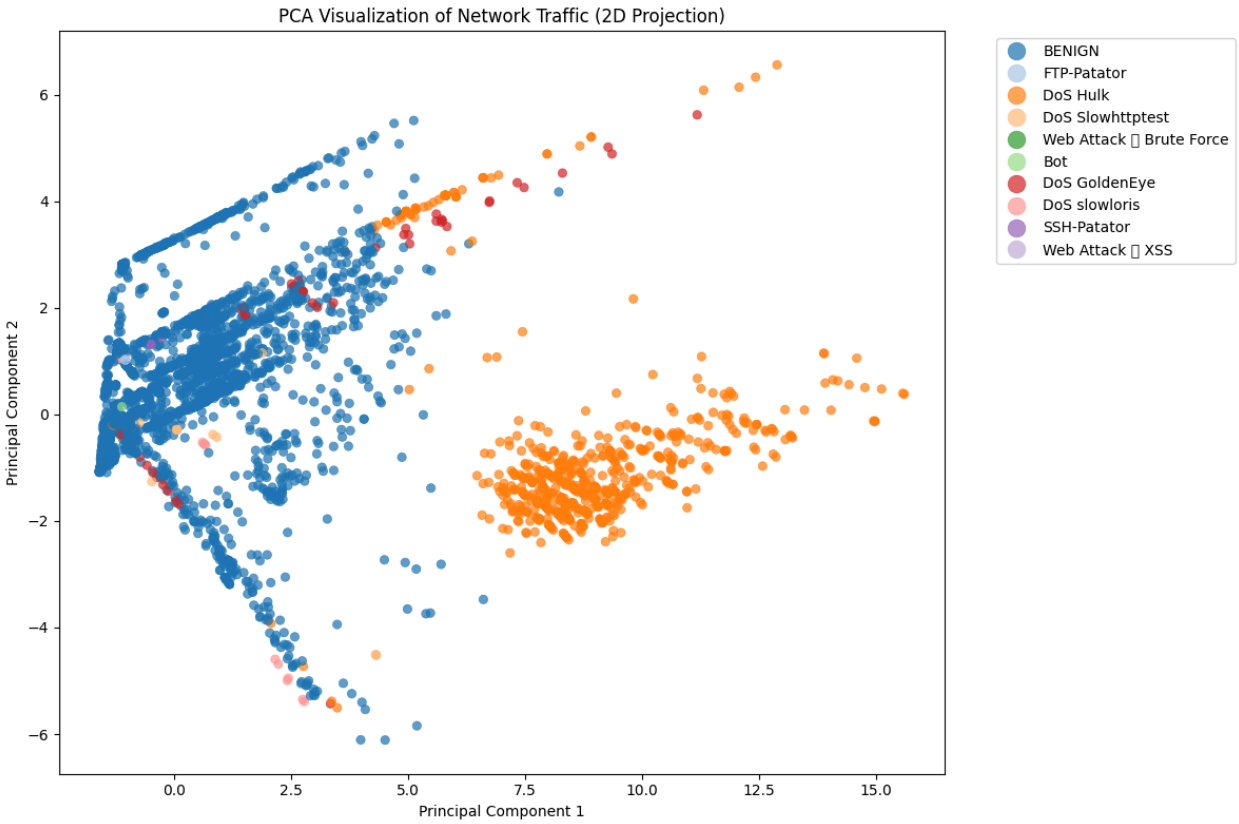
3.4 Μείωση Διαστάσεων και Οπτικοποίηση (PCA)

Προκειμένου να καταστεί δυνατή η χαρτογράφηση και η οπτική κατανόηση της τοπολογίας των δεδομένων, κρίθηκε αναγκαία η προβολή των 15 επιλεγμένων διαστάσεων σε έναν δισδιάστατο χώρο. Για τον σκοπό αυτό, εφαρμόστηκε η Ανάλυση Κύριων Συνιστωσών (ορολογιακά: Principal Component Analysis - εφεξής PCA), ένας γραμμικός μετασχηματισμός που δημιουργεί νέους, ασυσχέτιστους άξονες (τις κύριες συνιστώσες) οι οποίοι μεγιστοποιούν τη διακύμανση των δεδομένων. Πρέπει να σημειωθεί ότι το PCA χρησιμοποιήθηκε αποκλειστικά για τους σκοπούς της διερευνητικής οπτικοποίησης και όχι για τη συμπίεση των δεδομένων ενόψει της εκπαίδευσης των μοντέλων.

3.5 Υπολογιστικές Προκλήσεις κατά το PCA

Κατά την προσπάθεια αρχικής εφαρμογής του αλγορίθμου PCA στο σύνολο του dataset (άνω των 2,8 εκατομμυρίων εγγραφών), προέκυψε σοβαρό ζήτημα διαχείρισης υπολογιστικών πόρων αφού παρότι ο πίνακας συνδιακύμανσης για 15 χαρακτηριστικά έχει διαστάσεις μόλις 15x15, η δέσμευση ενδιάμεσων αντιγράφων στη μνήμη και η εκτέλεση της παραγοντοποίησης των ιδιαζουσών τιμών επί του πλήρους πίνακα δεδομένων (2.827.677 επι 15) οδήγησαν σε εξάντληση της διαθέσιμης μνήμης και τερματισμό της διαδικασίας.

Για την επίλυση αυτού του τεχνικού περιορισμού, χωρίς να αλλοιωθεί η στατιστική εγκυρότητα του γραφήματος, εφαρμόστηκε μια στρατηγική τυχαίας δειγματοληψίας. Συγκεκριμένα, εξήχθη ένα τυχαίο υποσύνολο 10.000 εγγραφών (με ορισμό της παραμέτρου **random_state=42** για σκοπούς αναπαραγωγιμότητας). Η λύση αυτή επέτρεψε την επιτυχή εκτέλεση του PCA, διατηρώντας ακέραια την κατανομή των βασικών κλάσεων.



Σχήμα 3.3: Δισδιάστατη προβολή των δεδομένων μέσω PCA (Δείγμα 10.000 εγγραφών). Αναδεικνύεται η γεωμετρική απομάκρυνση των επιθέσεων όγκου, ενώ καταγράφεται ταξική επικάλυψη στις επιθέσεις εφαρμογών.

Όπως παρατηρείται στο Σχήμα 3.3, η κανονική δικτυακή κίνηση (Benign) καταλαμβάνει μια κεντρική και εκτεταμένη περιοχή, επιβεβαιώνοντας την κυριαρχία της στο δίκτυο. Αντίθετα, οι επιθέσεις όγκου (όπως το DoS Hulk) διαχωρίζονται ευκρινώς, δημιουργώντας clusters σε απόσταση από την κανονική κίνηση. Το πιο ενδιαφέρον και κρίσιμο εύρημα, ωστόσο, αφορά ορισμένες στοχευμένες επιθέσεις σε επίπεδο εφαρμογής (π.χ. Web Attacks, SQL Injections), οι οποίες εμφανίζονται να επικαλύπτονται σχεδόν πλήρως με την κανονική κίνηση επιβεβαιώνοντας τη θεωρία: οι εν λόγω επιθέσεις χρησιμοποιούν αυθεντικά αιτήματα HTTP (π.χ. POST/GET requests), καθιστώντας τα δικτυακά τους χαρακτηριστικά (όγκος, χρόνος) πανομοιότυπα με αυτά της φυσιολογικής πλοήγησης. Σημαντικό βέβαια να αναφέρουμε πως αν και η επικάλυψη κλάσεων σε μια 2D προβολή PCA δεν αποδεικνύει μαθηματικά την απουσία linear separability στον αρχικό χώρο των 15 διαστάσεων (λόγω της απώλειας διακύμανσης κατά τη συμπίεση σε δύο άξονες), παρέχει μια ισχυρή οπτική ένδειξη της εγγύτητας των επιθέσεων επιπέδου εφαρμογής με την κανονική κίνηση, αιτιολογώντας τη δοκιμή μη-γραμμικών ταξινομητών στο Κεφάλαιο 4.

Κεφάλαιο 4: Εκπαίδευση και Συγκριτική Αξιολόγηση Μοντέλων

4.1 Θεωρητικό Υπόβαθρο Αλγορίθμων Μηχανικής Μάθησης

Πριν την παρουσίαση των πειραματικών αποτελεσμάτων, αξίζει να αναλυθεί η μαθηματική και θεωρητική φύση των αλγορίθμων που επιλέχθηκαν για την ταξινόμηση της δικτυακής κίνησης, με σκοπό να δικαιολογηθεί η συμπεριφορά τους στον πολυδιάστατο χώρο των δικτυακών δεδομένων.

4.1.1 Δέντρα Απόφασης (Decision Trees)

Τα Δέντρα Απόφασης αποτελούν μοντέλα μη παραμετρικής μάθησης που διαχωρίζουν τον χώρο των δεδομένων χρησιμοποιώντας σειριακούς κανόνες. Σε κάθε κόμβο, ο αλγόριθμος αναζητά το χαρακτηριστικό και το threshold που μεγιστοποιεί τον διαχωρισμό των κλάσεων (π.χ. Κανονική Κίνηση έναντι DDoS). Το κριτήριο που ελαχιστοποιείται συνήθως είναι η Ακαθαρσία Gini (Gini Impurity), η οποία υπολογίζεται μέσω του τύπου:

$$Gini = 1 - \sum_{i=1}^{C} p_i^2$$

όπου C είναι ο συνολικός αριθμός των κλάσεων και pi η πιθανότητα ένα τυχαία επιλεγμένο δείγμα να ανήκει στην κλάση i. Αν και τα δέντρα είναι εξαιρετικά στην αποτύπωση μη-γραμμικών σχέσεων, είναι επιρρεπή σε overfitting, καθώς τείνουν να "αποστηθίζουν" τον θόρυβο των δεδομένων εκπαίδευσης εάν το βάθος τους δεν περιοριστεί.

4.1.2 Τυχαία Δάση (Random Forest)

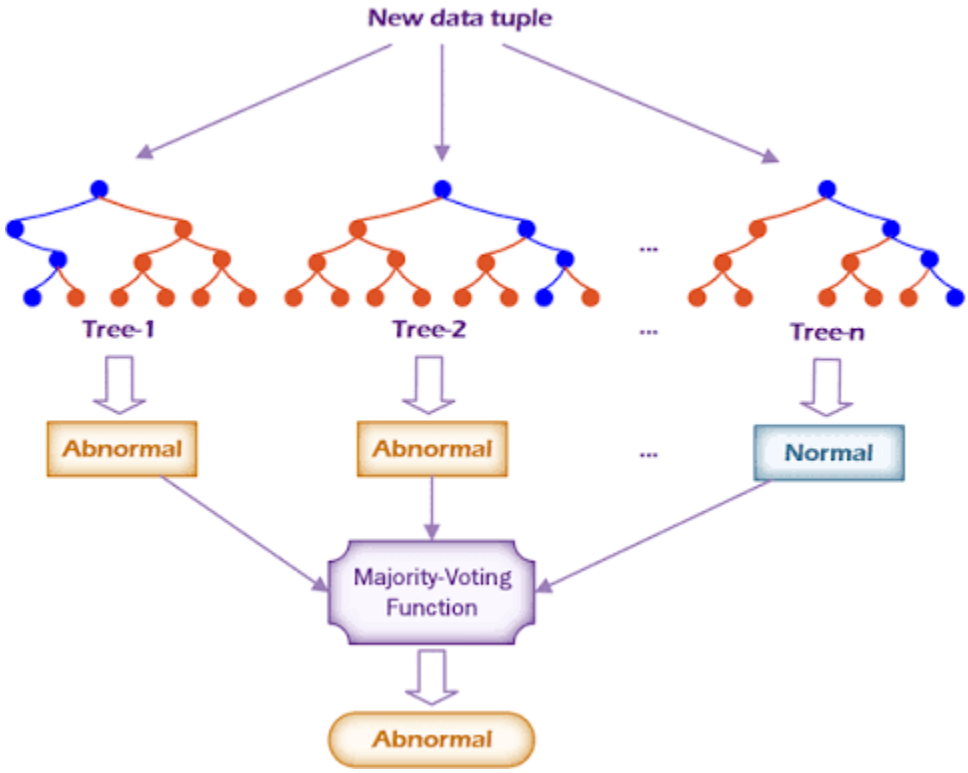
Για την επίλυση του προβλήματος του overfitting, επιλέχθηκε ο αλγόριθμος Random Forest. Πρόκειται για έναν αλγόριθμο συνόλου που βασίζεται στην τεχνική Bagging: ο αλγόριθμος κατασκευάζει ένα πλήθος B ανεξάρτητων δέντρων απόφασης (εδώ B=50). Κάθε δέντρο εκπαιδεύεται σε ένα τυχαίο υποσύνολο δεδομένων με επανατοποθέτηση

(bootstrap sample), ενώ σε κάθε διάσπαση κόμβου αξιολογείται μόνο ένα τυχαίο υποσύνολο των διαθέσιμων χαρακτηριστικών.

Η τελική πρόβλεψη y^ για ένα νέο δείγμα x προκύπτει από την πλειοψηφική ψηφοφορία όλων των δέντρων:

$$\hat{y} = \text{mode}\{h_1(x), h_2(x), ..., h_B(x)\}$$

Η μαθηματική ισχύς του Random Forest βασίζεται στο γεγονός ότι, μειώνοντας τη συσχέτιση μεταξύ των δέντρων, η συνολική διακύμανση του μοντέλου μειώνεται δραματικά (~ (s^2) / B), καθιστώντας το εξαιρετικά στιβαρό έναντι ανωμαλιών στη δικτυακή κίνηση [10].



Σχήμα 4.1: Αρχιτεκτονική του αλγορίθμου Τυχαίου Δάσους (Random Forest) και ο μηχανισμός πλειοψηφικής ψηφοφορίας.

4.1.3 Κ-Κοντινότεροι Γείτονες (K-Nearest Neighbors - k-NN)

Ο αλγόριθμος k-NN ανήκει στην κατηγορία της τεμπέλικης μάθησης, καθώς δεν κατασκευάζει εσωτερικό μοντέλο, αλλά αποθηκεύει τα δεδομένα εκπαίδευσης. Ταξινομεί

ένα νέο πακέτο δικτύου x βρίσκοντας τα k πιο κοντινά δείγματα στον χώρο (εδώ k=5). Η απόσταση υπολογίζεται συνήθως μέσω της Ευκλείδειας μετρικής:

$$d(p,q) = \sqrt{\sum_{i=1}^{n}(q_i - p_i)^2}$$

Δεδομένου ότι ο τύπος αθροίζει τις διαφορές των διαστάσεων, χαρακτηριστικά με μεγάλες αριθμητικές τιμές (όπως το Flow Duration σε μικροδευτερόλεπτα) θα κυριαρχούσαν στον υπολογισμό. Συνεπώς, η κανονικοποίηση (με StandardScaler) που υλοποιήθηκε στην προεπεξεργασία, βάσει του τύπου z ={x - μ} / σ, αποτελούσε αυστηρή μαθηματική αναγκαιότητα.

4.1.4 Λογιστική Παλινδρόμηση (Logistic Regression)

Η Λογιστική Παλινδρόμηση αποτελεί ένα γραμμικό μοντέλο που επιχειρεί να διαχωρίσει τις κλάσεις μέσω ενός hyperplane. Χρησιμοποιεί τη σιγμοειδή συνάρτηση για να μετατρέψει την έξοδο σε πιθανότητα P(Y=1|X):

$$P(x) = \frac{1}{1 + e^{-(\beta_0 + \beta_1 x_1 + \ldots + \beta_n x_n)}}$$

Λόγω της γραμμικής του φύσης, ο αλγόριθμος αναμένεται να υστερεί στη δικτυακή ανάλυση, καθώς οι διαφορές μεταξύ κανονικής κίνησης και πολύπλοκων επιθέσεων σπάνια διαχωρίζονται με μια απλή ευθεία γραμμή.

4.1.5 Επιβλεπόμενη Μάθηση (Supervised Learning) στην Ταξινόμηση Κίνησης

Στο παρόν στάδιο της έρευνας, αξιολογήθηκε η απόδοση τεσσάρων βασικών αλγορίθμων επιβλεπόμενης μάθησης (Decision Tree, Random Forest, K-Nearest Neighbors και Logistic Regression) στην ταξινόμηση της δικτυακής κίνησης. Πρέπει να σημειωθεί ότι η προσέγγιση σχεδιάστηκε ως Multiclass Classification πρόβλημα. Το μοντέλο δεν κάνει μόνο διαχωρισμό της κίνησης σε "Κανονική" ή "Επίθεση", αλλά

αναγνωρίζει τον ακριβή τύπο της απειλής ανάμεσα σε πολλαπλές, εξαιρετικά διαφορετικές κλάσεις (π.χ. DDoS, Brute Force, Web Attacks). Αρχικός στόχος ήταν η δημιουργία ενός ισχυρού baseline, χρησιμοποιώντας ως διάνυσμα εισόδου αποκλειστικά τα 15 κορυφαία χαρακτηριστικά που προέκυψαν από το προηγούμενο στάδιο με την επιλογή χαρακτηριστικών.

Το Πρόβλημα του Data Shift και οι Κίνδυνοι του Cross-Validation

Αξίζει να σημειωθεί ότι κατά τη διάρκεια των πειραμάτων, αναδείχθηκε μια εξαιρετικά κρίσιμη παράμετρος που αφορά την επιχειρησιακή και χρηστική πραγματικότητα των μοντέλων Μηχανικής Μάθησης. Πριν την εφαρμογή random splitting, τα μοντέλα δοκιμάστηκαν σε αυστηρό time-aware splitting. Σε αυτό το σενάριο, το σύστημα εκπαιδεύτηκε αποκλειστικά στην κίνηση των πρώτων ημερών της εβδομάδας και κλήθηκε να προβλέψει τη δικτυακή κίνηση της Παρασκευής.

```
Training Baseline Models in the 15 Features we found

-> Training model: Decision Tree...
-> Training model: Logistic Regression...
-> Training model: Random Forest (Light)...
-> Training model: K-Nearest Neighbors...

--- Benchmark table of Models ---
                Model  Accuracy (%)  Precision (W)  Recall (W)  F1-Score (W)  Training Time (s)
        Decision Tree        49.122         0.2609      0.4912        0.3408              18.30
  Logistic Regression        48.675         0.2806      0.4868        0.3560             148.53
Random Forest (Light)        49.131         0.2830      0.4913        0.3591              38.23
  K-Nearest Neighbors        48.989         0.2743      0.4899        0.3516              27.81
```

Πίνακας 4.1.5.1: Συγκριτικός πίνακας απόδοσης των αλγορίθμων ταξινόμησης σε time-aware splitting προβλέποντας τις κινήσεις της τελευταίας μέρας.

Σε εκείνη τη δοκιμή, η απόδοση κατέρρευσε περίπου στο 49%. Αυτό συμβαίνει διότι στο σύνολο δεδομένων, συγκεκριμένες κατηγορίες επιθέσεων βρίσκονται αποκλειστικά στο τελευταίο 20% των χρονολογικών εγγραφών και έτσι το μοντέλο απέτυχε όταν αντιμετώπισε επιθέσεις (όπως η μαζική επίθεση DDoS της Παρασκευής) τις οποίες δεν είχε συναντήσει ποτέ κατά τη φάση της εκπαίδευσης. Συνεπώς, η πτώση της απόδοσης δεν αποτελεί αμιγές φαινόμενο Concept Drift, αλλά συνιστά πρόβλημα Μη εμφανισθείσας Κλάσης / Ανοικτού κόσμου και Χρονικής Μετατόπισης Κατανομής. Για τον εντοπισμό τελείως αγνώστων επιθέσεων απαιτείται είτε δυαδική ταξινόμηση (Benign / Attack) είτε ανίχνευση ανωμαλιών (όπως στην ενότητα 4.2). Παράλληλα το εύρημα

αυτό τεκμηριώνει την ανάγκη αποφυγής του Random k-fold Cross Validation [12] σε χρονοσειρές δικτύου λόγω διαρροής μελλοντικής πληροφορίας στο παρελθόν (το φαινόμενο time leakage), προκρίνοντας αντ αυτου μεθόδους χρονικά ενήμερης ή ομαδοποιημένης επικύρωσης.

Hyperparameter Tuning και Εξαγωγή Baseline Μετρικών

Για την εξαγωγή των τελικών συγκριτικών baseline μετρικών και τη δίκαιη αξιολόγηση των αλγορίθμων, τα δεδομένα διαχωρίστηκαν τελικά με τυχαίο ανακάτεμα, εξασφαλίζοντας την ομοιόμορφη κατανομή των επιθέσεων τόσο στο train set όσο και στο test set. Γνωρίζοντας την έντονη ταξική ανισορροπία που συζητήθηκε στο Κεφάλαιο 2, η αξιολόγηση δεν βασίστηκε αποκλειστικά στο ποσοστό Accuracy μια και μπορεί να είναι παραπλανητικό, (θυμίζουμε, διότι αν βασιζόμασταν μόνο στο accuracy, ένα μοντέλο που θα προέβλεπε πάντα την πλειοψηφική κανονική κίνηση θα πετύχαινε πολύ υψηλό ποσοστό -άνω του 80%- , ενώ θα απέτυχε πλήρως να εντοπίσει τις κρίσιμες αλλά σπάνιες επιθέσεις - όπως το Heartbleed ή τα SQL Injections). Αντίθετα χρησιμοποιούμε το σταθμισμένο F1-Score με τον τύπο

$$F1 = 2 \cdot \frac{Precision \cdot Recall}{Precision + Recall}$$

ο οποίος αποτελεί τον αρμονικό μέσο όρο Precision και Recall

Ως μέρος της βελτιστοποίησης hyperparameter, ρυθμίστηκαν συγκεκριμένες παράμετροι των μοντέλων, όπως ο μέγιστος αριθμός επαναλήψεων (**max_iter**) για τους αλγορίθμους βελτιστοποίησης και το μέγεθος/βάθος των δέντρων απόφασης, προκειμένου να επιτευχθεί η βέλτιστη μαθηματική σύγκλιση.

```
Remaking train/test sets with shuffle for baseline extraction

-> Training Model Decision Tree...
-> Training Model Logistic Regression...
-> Training Model Random Forest...
-> Training Model K-Nearest Neighbors...

--- Benchmark Table of Models (Shuffled Baseline) ---
              Model  Accuracy (%)  Precision (W)  Recall (W)  F1-Score (W)  F1-Score (Macro)  Training Time (s)
      Decision Tree        99.852         0.9985      0.9985        0.9985            0.8480              21.29
Logistic Regression        87.170         0.8289      0.8717        0.8431            0.3053             352.02
      Random Forest        99.876         0.9987      0.9988        0.9987            0.8417              43.38
K-Nearest Neighbors        99.796         0.9979      0.9980        0.9979            0.8070              33.29

--- Per-Class Evaluation Report (Random Forest) ---
                          precision    recall  f1-score   support

                  BENIGN     0.9996    0.9992    0.9994    454012
                     Bot     0.8519    0.7383    0.7910       405
                    DDoS     0.9998    0.9993    0.9996     25771
           DoS GoldenEye     0.9965    0.9980    0.9972      1973
                DoS Hulk     0.9985    0.9997    0.9991     46032
        DoS Slowhttptest     0.9850    0.9947    0.9898      1124
           DoS slowloris     0.9974    0.9895    0.9934      1145
             FTP-Patator     0.9987    0.9993    0.9990      1519
              Heartbleed     1.0000    1.0000    1.0000         2
            Infiltration     1.0000    0.5714    0.7273         7
                PortScan     0.9933    0.9997    0.9964     31954
             SSH-Patator     1.0000    0.9991    0.9996      1138
  Web Attack  Brute Force     0.7233    0.7115    0.7174       305
Web Attack  Sql Injection     0.0000    0.0000    0.0000         8
         Web Attack  XSS     0.4286    0.4043    0.4161       141

                accuracy                         0.9988    565536
               macro avg     0.8648    0.8269    0.8417    565536
            weighted avg     0.9987    0.9988    0.9987    565536
```

Πίνακας 4.1.5.2: Συγκριτικός πίνακας απόδοσης των αλγορίθμων ταξινόμησης στο σύνολο δοκιμής, με βάση το Weighted F1-Score και τον χρόνο εκπαίδευσης.

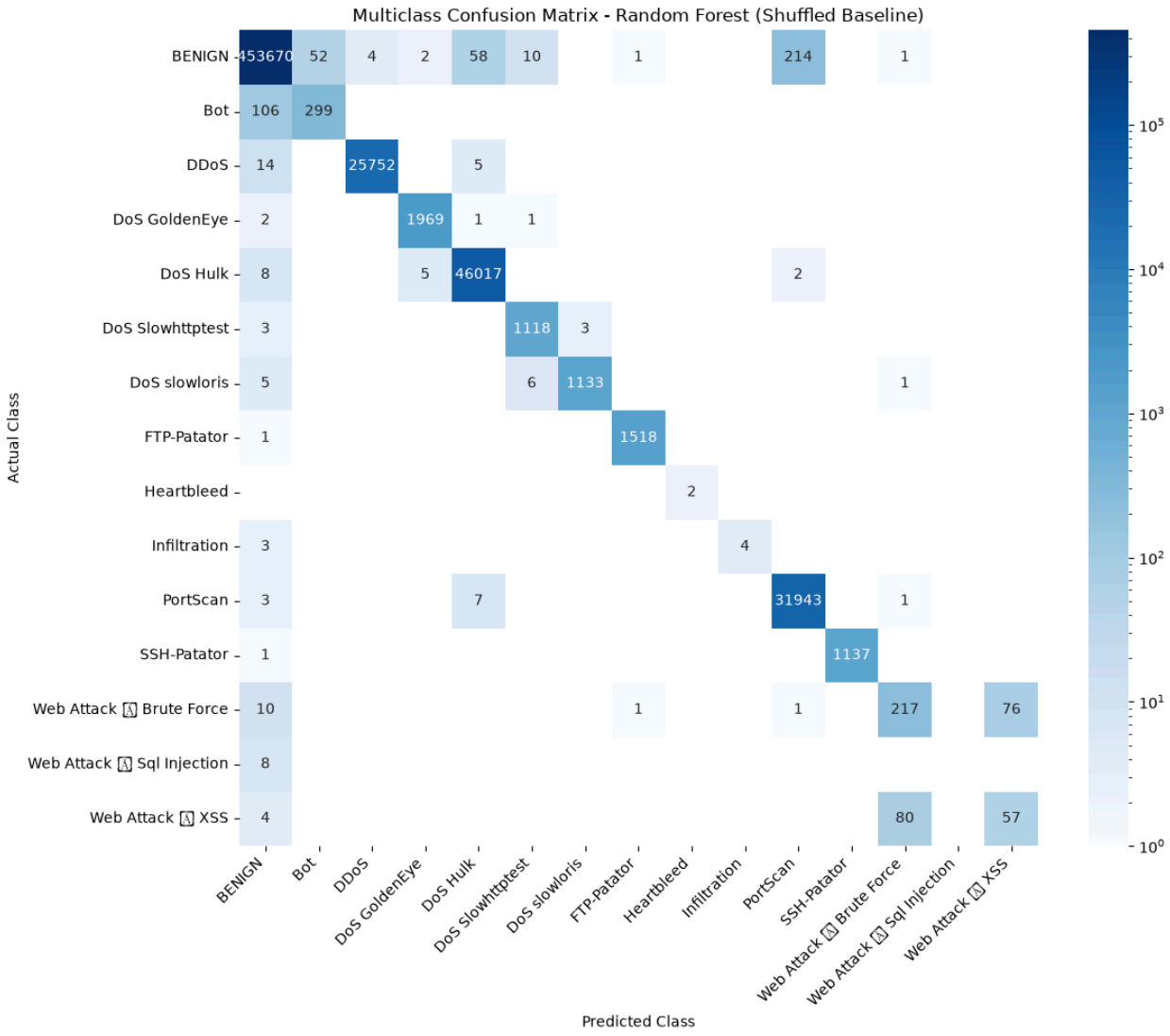
Ανάλυση:

Τα αποτελέσματα του συγκριτικού πίνακα ανέδειξαν την ξεκάθαρη υπεροχή των δενδρικών αλγορίθμων, επιβεβαιώνοντας τη θεωρητική τους καταλληλόλητα για δικτυακά δεδομένα:

- **Decision Tree & Random Forest:** Και τα δύο μοντέλα σημείωσαν εξαιρετική συνολική απόδοση, αγγίζοντας ποσοστά Accuracy 99.85% και 99.88% αντίστοιχα (με Weighted F1-Score 0.9985 και 0.9987 και χρόνους εκπαίδευσης 21.29s και 43.38s). Ωστόσο, εξετάζοντας το Macro F1-Score (0.8480 και 0.8417 αντίστοιχα) καθώς και τον αναλυτικό πίνακα ανά κλάση (Πίνακας 4.1.5.2) και τον πολυταξινομικό Πίνακα Σύγχυσης (Πίνακας 4.1.5.3), αναδεικνύεται η επίδραση της ακραίας ταξικής ανισορροπίας: ενώ στις επιθέσεις όγκου (π.χ. DDoS, DoS Hulk, PortScan) το F1-Score υπερβαίνει το 99.9%, στις εξαιρετικά ολιγάριθμες κλάσεις (όπως το SQL Injection, το Infiltration και το Bot με F1-Score 0.7910) η

ανάκτηση (Recall) είναι χαμηλότερη λόγω του περιορισμένου πλήθους δειγμάτων εκπαίδευσης.

- **K-Nearest Neighbors (k-NN):** Ως αλγόριθμος βασισμένος στη μέτρηση αποστάσεων, ανταποκρίθηκε εξίσου καλά στο πρόβλημα. Το γεγονός αυτό επιβεβαιώνει τη χρησιμότητα και την αναγκαιότητα της κανονικοποίησης με τον standard scaler που εφαρμόστηκε στο προηγούμενο στάδιο, η οποία απέτρεψε την κυριαρχία χαρακτηριστικών με μεγάλες αριθμητικές τιμές.
- **Logistic Regression:** Αντίθετα με τα παραπάνω, η Logistic Regression υπο-απέδωσε αισθητά με Accuracy 87.17%, Weighted F1 0.8431 και εξαιρετικά χαμηλό Macro F1 (0.3053), απαιτώντας παράλληλα δυσανάλογο χρόνο εκπαίδευσης στα 352.02 δευτερόλεπτα. Το συγκεκριμένο εύρημα επιβεβαιώνει τη φύση της δικτυακής κίνησης, η οποία χαρακτηρίζεται από έλλειψη γραμμικής διαχωρισιμότητας, καθιστώντας τα απλά γραμμικά μαθηματικά σύνορα ανεπαρκή.



Πίνακας 4.1.5.3: Multiclass Confusion Matrix

Συμπέρασμα Επιβλεπόμενης Μάθησης

Συμπεραίνεται επομένως πως, ενώ τα μοντέλα επιτυγχάνουν εξαιρετικά υψηλή ακρίβεια όταν αξιολογούνται υπό συνθήκες random splitting -έχοντας δηλαδή δει δείγματα από όλες τις κατανομές-, η πραγματική ικανότητα γενίκευσής τους σε εντελώς νέες, άγνωστες επιθέσεις παραμένει μεγάλη τεχνική πρόκληση.

4.2 Μη Επιβλεπόμενη Μάθηση και Ανίχνευση Ανωμαλιών

4.2.1 Θεωρητικές Προσεγγίζεις και η Επιλογή του Isolation Forest

Στη βιβλιογραφία του unsupervised learning για την ασφάλεια των δικτύων, διακρίνονται δύο κύριες προσεγγίσεις: η Ομαδοποίηση (Clustering) και η Ανίχνευση Ακραίων Τιμών (Outlier Detection). Το Clustering προσπαθεί να βρει φυσικές ομάδες στα δεδομένα, μια διαδικασία εξαιρετικά χρήσιμη για την ανακάλυψη ευρύτερων μοτίβων επισκεψιμότητας αλλά λιγότερο αποτελεσματική για τον εντοπισμό σπανίων επιθέσεων. Αντίθετα το Outlier Detection εστιάζει αποκλειστικά στη εύρεση στατιστικού noise. Για αυτο το σκοπο εκτός από το Isolation Forest - που επιλέχθηκε στη παρούσα μελέτη - υπάρχουν εξίσου ισχυρές μέθοδοι όπως τα One-Class SVM που προσπαθούν να κλείσουν την κανονική κίνηση σε μια υπερσφαίρα [13], και τα Local Outlier Factor που μετράνε την (τοπική) πυκνότητα των πακέτων αντίστοιχα [14].

Το Isolation Forest επιλέχθηκε διότι, αντί να χαρτογραφεί το προφίλ της "κανονικής" κίνησης, επιχειρεί να απομονώσει απευθείας τις ανωμαλίες, δημιουργώντας τυχαίους διαχωρισμούς στα χαρακτηριστικά, υποθέτοντας ότι τα κακόβουλα πακέτα -όντας στατιστικά διαφορετικά και σπάνια- απαιτούν λιγότερους διαχωρισμούς για να απομονωθούν σε έναν κόμβο (αρα μικρότερο path length).

4.2.2 Εκπαίδευση, Κατώφλια και Προκλήσεις των Δεδομένων

Η ακριβής επιλογή του threshold αποτελεί ένα ιδιαίτερα σύνθετο πρόβλημα στο πεδίο της ανίχνευσης ανωμαλιών. Στη παρούσα πειραματική διάταξη, ορίστηκε η παράμετρος του contamination στο 5% αναγκάζοντας ουσιαστικά τον αλγόριθμο να κόψει το 5% των πιό ακραίων εγγραφών. Το μοντέλο εκπαιδεύτηκε αποκλειστικά σε 1.817.110 εγγραφές κανονικής κίνησης προκειμένου να μάθει το αποτύπωμα του φυσιολογικού δικτύου, και στη συνέχεια αξιολογήθηκε στο σύνολο δοκιμής.

Γενικότερα, η αξιολόγηση αυτών των μοντέλων είναι εξαιρετικά δύσκολη διότι οι ετικέτες στα dataset είναι συχνά αδύναμες ή ελλιπείς. Όπως διαπιστώθηκε, το CIC-IDS2017 δεν έχει μόνο ογκομετρικές επιθέσεις, αλλα και Infiltration, Web Attacks και heartbleed, επιθέσεις σχεδιασμένες να μιμούνται τελεια τη κανονική ανθρώπινη συμπεριφορά. Έτσι, ένας unsupervised αλγόριθμος που ψάχνει μόνο για στατιστικές ανωμαλίες χωρις labels δυσκολεύεται σημαντικά να εντοπίσει επιθέσεις επιπέδου εφαρμογής όπως το SQL Injection, καθώς τα στατιστικά χαρακτηριστικά επιπέδου ροής συχνά δεν περιέχουν επαρκή διαχωριστική πληροφορία χωρίς επιθεώρηση του ίδιου του payload

```
Unsupervised learning with Isolation Forrest

-> Training exclusively on 1817110 regs of Benign Traffic
-> Predict on unknown data (Test Set) with attacks...
Training Time & Prediction: 8.06 seconds

--- Report (Anomaly Detection) ---
                    precision    recall  f1-score   support

Anomaly/Attack (-1)       0.68      0.44      0.54    111524
  Normal/Benign (1)       0.87      0.95      0.91    454012

           accuracy                           0.85    565536
          macro avg       0.78      0.70      0.72    565536
       weighted avg       0.84      0.85      0.84    565536
```

Σχήμα 4.2.2: Αναφορά απόδοσης του αλγορίθμου Isolation Forest στην ανίχνευση ανωμαλιών στο σύνολο δοκιμής, παρουσιάζοντας χρόνο πρόβλεψης 8.06 δευτερολέπτων.

4.2.3 Επιχειρησιακή Ανάλυση Σφαλμάτων: Alert Fatigue

Η εφαρμογή της ανίχνευσης ανωμαλιών στη δικτυακή κίνηση, αν και θεωρητικά ιδανική για την αντιμετώπιση Zero-Day επιθέσεων, στην πράξη παρουσιάζει τεράστιες δυσκολίες. Αναλύοντας τα αποτελέσματα του Σχήματος 4.2.2, το Isolation Forest μοντέλο σημείωσε Precision 68% και Recall 44%), με τα εξής κρίσιμα συμπεράσματα:

- Το μοντέλο εμφάνισε ενα ποσοστό της τάξης του 32% σε False Discovery Rate (68% Precision), ενώ το πραγματικό False Positive Rate επι του συνόλου κανονικης κίνησης ήταν 5% (Recall(benign) = 95%). Σε ένα πραγματικό εταιρικό δίκτυο που δέχεται εκατομμύρια πακέτα τη μέρα, ένα φαινομενικά “μικρό” ποσοστό σφάλματος μεταφράζεται σε χιλιάδες εσφαλμένους συναγερμούς καθημερινά. Αυτό οδηγεί στο φαινόμενο του Alert Fatigue (οπως αναφέραμε και στο κεφάλαιο 1) κατι που για τους αναλυτές του SoC είναι πρόβλημα οι οποίοι καταλήγουν νομοτελειακά να αγνοούν το σύστημα ακυρώνοντας την αξία της ανίχνευσης.

- Το thresholding στα anomaly scores είναι μια “λεπτή ισορροπία”. Αν αυξήθεί η ευαισθησία (π.χ. contamination 10%), το Recall θα ανέβει, εντοπίζοντας περισσότερες άγνωστες επιθέσεις, αλλά τα False Positives θα εκτοξευτούν

κάνοντας το σύστημα μη διαχειρίσιμο. Στον αντίποδα, αν μειωθεί η ευαισθησία (π.χ. contamination 1%), το σύστημα θα είναι “ήσυχο”, αλλά οι εισβολείς θα περάσουν απαρατήρητοι επομένως δε μπορούμε να έχουμε μια μαθηματικα ακριβείς τιμή στα χαοτικά δεδομένα ενός δικτύου. Ο παρακάτω πίνακας (Πινακας 4.2.3) επιβεβαιώνει πειραματικά το trade-off ευαισθησίας: αυξάνοντας το contamination από 1% σε 20%, το σύστημα εντοπίζει μεν περισσότερες επιθέσεις (το Recall αυξάνεται), αλλά το ποσοστό των ψευδών συναγερμών (και συνεπώς ο κίνδυνος για Alert Fatigue) εκτοξεύεται, καθιστώντας το σύστημα μη διαχειρίσιμο.

```
--- Contamination Sensitivity Analysis -Threshold Impostance-
Contamination  Precision (-1)  Recall (-1)  F1-Score (-1)  FDR (False Alarms %)
           1%          0.9078       0.4081         0.5631                  9.22
           5%          0.6843       0.4437         0.5383                 31.57
          10%          0.5247       0.4494         0.4842                 47.53
          20%          0.3631       0.4630         0.4070                 63.69
```

Σχήμα 4.2.3: Πίνακας ανάλυσης ευαισθησίας σε διαφορετικά σενάρια μολυσματικού επιπέδου.

Μια εκτενείς μελέτη των false positives αποκαλύπτει μια ενδιαφέρουσα ακαδημαϊκή πτυχή: μια εγγραφή που το ο αλγόριθμος χαρακτήρισε ως Ανωμαλία αλλα το dataset φέρει ετικέτα Benign, δεν αποτελεί απαραίτητα λάθος του αλγόριθμου, αφου σε τεράστια σύνολα δεδομένων οι ετικέτες μπαίνουν συχνά αυτοματοποιημένα. Αυτα τα false positives μπορει στη πραγματικότητα να είναι λανθασμένες ρυθμίσεις δικτύου, νόμιμες αλλα αρκετά σπάνιες συμπεριφορές, (πχ μαζικό backup του μήνα) ή ακόμα και αχαρτογράφητες επιθέσεις που οι δημιουργοι του dataset απέτυχαν να καταγράψουν. Επομένως οι ανωμαλίες είναι ενδιαφέρουσες και χρήζουν περαιτέρω ανάλυσης απο ανθρώπινους αναλυτές, ανεξαρτήτως της επίσημης ετικέτας που φέρουν.

4.3 Χρονική Μοντελοποίηση (Time-Based modeling): Δίκτυα Botnet και επιθέσεις DDoS

4.3.1 Θεωρητικό Υπόβαθρο: Μοτίβα Επικοινωνίας και Περιορισμοί Μεμονωμένης Ανάλυσης

Στα προηγούμενα στάδια της ανάλυσης, η δικτυακή κίνηση προσεγγίστηκε εξετάζοντας κάθε δικτυακή ροή ως μια ανεξάρτητη οντότητα. Παρότι η προσέγγιση αυτή είναι

αποδοτική για μεμονωμένα περιστατικά, ορισμένες κατηγορίες επιθέσεων δεν μπορούν να γίνουν πλήρως αντιληπτές εάν αγνοηθεί η χρονική τους αλληλουχία. Δύο χαρακτηριστικά παραδείγματα τέτοιων απειλών αποτελούν τα δίκτυα μολυσμένων υπολογιστών (Botnets) και οι Κατανεμημένες Επιθέσεις Άρνησης Εξυπηρέτησης (Distributed Denial of Service - DDoS).

Αρχικά είναι σημαντικό να δικαιολογηθεί η επιλογή των χαρακτηριστικών για την ανίχνευση αυτών των απειλών, μελετωντας τη θεωρητικη τους βαση. Ο κυκλος της ζωης ενος botnet αποτελειται απο μια συνεχεις επικοινωνια με τους διακομιστες ελεγχου, συχνα ως beaconing, οπου το botnet στελνει μικρα ρυθμικα πακετα στο δικτυο [15] τα οποια ενημερωνουν τον επιτιθέμενο οτι ο υπολογιστης-ζομπι ειναι ακομα ενεργος. Απ την αλλη οι ογκομετρικες επιθεσεις οπως ειναι η DDoS δε προσπαθουν να παραβιάσουν καποιο κωδικο, αλλα αντιθετα να “πνιξουν” το στοχο στελνοντας ενα τεραστιο ογκο πακετων σε λιγα μολις δευτερολεπτα. Και στις δυο περιπτωσεις, όπως επιβεβαιώνεται στη διεθνή βιβλιογραφία, το χαρακτηριστικο που μας ενδιαφερει ειναι ο ρυθμος και η συχνότητα πακετων [16]. Ετσι, στοιχεια που διαλεξαμε προηγουμενως οπως οι αποκλίσεις στο χρονο αφιξης των πακετων, και το μεγεθος των πακετων αποτελουν τους κυριους δεικτες για την αναγνωριση τέτοιων συμπεριφορών.

4.3.2 Σειριακή Συνάθροιση Ροών Σταθερού Πλήθους (Fixed-Count Sequential Flow Aggregation)

Προκειμένου οι αλγόριθμοι Μηχανικής Μάθησης να αντιληφθούν αυτόν τον ρυθμό, κρίθηκε αναγκαία η μεταβολή του τρόπου σάρωσης των δεδομένων, εισάγοντας τη Χρονική Μοντελοποίηση (Time-Based Modeling - Μοντελοποίηση βάση Χρόνου για δεδομένα που αλλάζουν παροδικά). Αντί της αξιολόγησης μεμονωμένων ροών, υλοποιήθηκε μια τεχνική κυλιόμενων χρονικών παραθύρων, ομαδοποιώντας τα δεδομένα σε σταθερά διαστήματα (στην προκειμένη περίπτωση, ομάδες 50 διαδοχικών ροών).

Δεδομένου ότι η στήλη της χρονικής σήμανσης (TImestamp) αφαιρέθηκε κατά την προεπεξεργασία προς αποφυγή διαρροής πληροφορίας, υλοποιήθηκε η τεχνική Σειριακής Συνάθροισης Κυλιόμενου Παραθύρου Σταθερού Πλήθους (Fixed-Count Sequential Aggregation). Ουσιαστικά, οι χρονολογικά διατεταγμένες ροές ομαδοποιούνται σε επικαλυπτόμενα παράθυρα μεγέθους $W = 50$ διαδοχικών ροών με βήμα ολίσθησης stride = 1 ροή. Για κάθε παράθυρο υπολογίζεται η αριθμητική μέση τιμή και των 15 επιλεγμένων χαρακτηριστικών, ενώ ως ετικέτα του παραθύρου ορίζεται η δυαδική κατάσταση (0 = Benign, 1 = Attack) της τρέχουσας ροής t. Στα όρια έναρξης ή

στη λήξης μιας επίθεσης, το κυλιόμενο παράθυρο ενσωματώνει σταδιακά τις νέες ροές, λειτουργώντας ως φίλτρο εξομάλυνσης θορύβου.

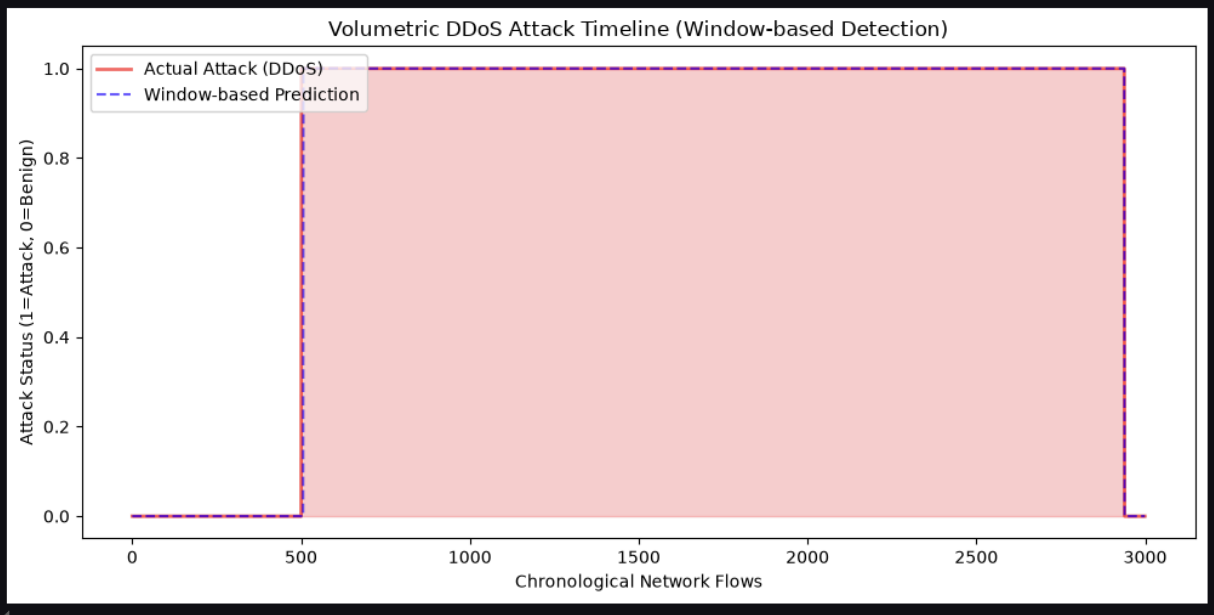
Η τεχνική αυτή εξάγει συγκεντρωτικά στατιστικά (όπως η μέση συχνότητα, ο μέσος όγκος και η αλληλουχία των πακέτων), επιτρέποντας στο μοντέλο να αποτυπώσει τη μακρο-συμπεριφορά της κίνησης και να εντοπίσει συντονισμένα μοτίβα που θα περνούσαν απαρατήρητα σε μια στατική, per-flow ανάλυση.

4.3.3 Πειραματική Αξιολόγηση και Οπτικοποίηση

Έπειτα, για την αξιολόγηση της προσέγγισης εκπαιδευτηκαν δυο δυαδικοι ταξινομητες χρησιμοποιώντας τον αλγόριθμο του Random Forest: ο πρωτος εκπαιδευτηκε στα ακατέργαστα μεμονωμενα δεδομενα, και ο δευτερος στα συγκεντρωτικά χρονικα παράθυρα. Στη συνεχεια τα δεδομενα δοκιμης χωριστηκαν με αυστηρη χρονολογικη σειρα, ωστε να προσομοιωθεί η ροή των γεγονότων στον πραγματικο χρονο εμφανισης των επιθεσεων.

```
Extracting slice to prevent RAM overflow...
Aggregating flows into sequential windows to capture attack rhythm...
Training models (Per-flow vs Window-based)...

--- Model Comparison ---
Per-flow Classification F1-Score:     0.9979
Window-based Classification F1-Score: 0.9973
Locating a volumetric DDoS attack for visualization...
```



Σχήμα 4.3: Σύγκριση απόδοσης μοντέλων και οπτικοποίηση της χρονικής ανίχνευσης μιας ογκομετρικής επίθεσης DDoS μέσω της μεθόδου Window-Based Detection (δείγμα 3000 διαδοχικών ροών). Η κόκκινη γραμμή αντιπροσωπεύει την πραγματική DDoS επίθεση ενώ η διακεκομμένη μπλέ γραμμή την πρόβλεψη απο χρονική συνάθροιση.

Οπως αποτυπώνεται στα μετρικά του κώδικα (Σχήμα 4.3), το μοντέλο Per-flow πέτυχε F1-Score 99.79%, ενώ το Window-based 99.73%. Παρά την ελάχιστη αυτή πτώση στο απόλυτο στατιστικό νούμερο, η επιχειρησιακή υπεροχή της χρονικής μοντελοποίησης αποτυπώνεται ξεκάθαρα και στο γράφημα ενός τυχαίου στιγμιότυπου 3.000 ροών.

Η πραγματικη επιθεση με DDoS σκιαγραφείται με τη κοκκινη περιοχη ενω η προβλεψη του μοντελου με τη μπλε διακεκομμένη γραμμή, η οποια οχι μονο εντοπιζει την εναρξη και της επιθεσης σχεδον ακαριαια, αλλα διατηρει και το συναγερμο ενεργο καθολη τη διαρκεια της, αγνοώντας τον φυσιολογικο “θορυβο” του δικτυου χωρίς στιγμιαίες διακοπές και επιβεβαιώνοντας ότι πρακτικα η επέκταση της ανάλυσης μέσω χρονικής συνάθροισης αποτελεί ένα εξαιρετικά αξιόπιστο και λειτουργικό εργαλείο για τα Κέντρα Επιχειρήσεων στην καταπολέμηση επιθέσεων όγκου (όπως το εξεταζόμενο σενάριο DDoS), ενώ η αντίστοιχη αξιολόγηση σε περιοδική κίνηση Botnet αποτελεί αντικείμενο μελλοντικής επέκτασης.

4.4 Deep learning στην Ανάλυση Δικτυακής Κίνησης

Γενικότερα, το Deep Learning έχει φέρει την επανάσταση σε αρκετούς τομείς της καθημερινότητας όπως το computer vision, ή την επεξεργασία φυσικής γλώσσας. Στη κυβερνοασφάλεια, αρχιτεκτονικές όπως τα CNN δίκτυα ή τα RNN δίκτυα διαπρέπουν όταν αναλύουν ωμά bytes δεδομένων. Ωστόσο η παρούσα έρευνα δεν λειτουργεί σε επίπεδο ακατέργαστων πακέτων αλλα επικεντρώνεται σε δομημένα πινακοποιημένα δεδομένα, δηλαδη σε εναν 2D πίνακα που περιέχει προκαθορισμένα αριθμητικά χαρακτηριστικά τα οποία έχουν ήδη εξαχθεί στο στάδιο της προεπεξεργασίας.

4.4.1 Αρχιτεκτονική Μοντέλου MLP

Προκειμένου να διερευνηθεί εάν το Deep Learning προσφέρει συγκριτικά πλεονεκτήματα σε τέτοιου είδους δεδομένα έναντι της παραδοσιακής Μηχανικής Μάθησης, αναπτύχθηκε ένα Πολυεπίπεδο Perceptron (Multi-Layer Perceptron - MLP). Πρόκειται για ένα πλήρως συνδεδεμένο τεχνητό νευρωνικό δίκτυο εμπρόσθιας τροφοδότησης το οποίο εκπαιδεύτηκε αποκλειστικά πάνω στα 15 επιλεγμένα

χαρακτηριστικά της κίνησης και δομήθηκε με δύο κρυφά επίπεδα, αποτελούμενα από 64 και 32 νευρώνες αντίστοιχα. Η αρχιτεκτονική αυτή χρησιμοποιεί μη-γραμμικές συναρτήσεις ενεργοποίησης και βελτιστοποιεί τα συναπτικά της weights μέσω ενός αλγορίθμου backpropagation, ελαχιστοποιώντας το εκάστοτε σφάλμα πρόβλεψης.

```
--- Deep Learning vs Traditional ML Comparison ---
           Model  Accuracy (%)  Precision  Recall  F1-Score  Time (sec)
   Random Forest         99.86     0.9985  0.9986    0.9985        2.85
MLP (Neural Net)         95.62     0.9616  0.9562    0.9570       28.86
```

Σχήμα 4.4: Συγκριτική αξιολόγηση απόδοσης και υπολογιστικού κόστους μεταξύ του παραδοσιακού αλγορίθμου Random Forest και του Νευρωνικού Δικτύου MLP (Multi-Layer Perceptron).

Η συγκριτική αξιολόγηση μεταξυ του βελτιστου παραδοσιακου αλγοριθμου (random forest) και του MLP δίνει σαφή απάντηση στο ερωτημα “αν το Deep Learning πλεονεκτεί στο συγκεκριμένο επιχειρησιακό πρόβλημα”. Όπως προκύπτει, υπό την επιλεγμένη αρχιτεκτονκή (δύο κρυφά επίπεδα 64 και 32 νευρώνων), το συγκεκριμένο σύνολο 15 πινακοποιημένων χαρακτηριστικών και το διαθέσιμο υλικό εκτέλεσης, το MLP δε προσέφερε πλεονεκτήματα απόδοσης έναντι του Random Forest (95.62% έναντι 99.86%), ενώ παράλληλα απάιτησε και σημαντικά μεγαλύτερο χρόνο εκπαίδευσης. Ειδικότερα:

Το μοντέλο (Σχήμα 4.4) σημείωσε σημαντικά υπολειπόμενη ακρίβεια απο το Random Forest, επιβεβαιώνοντας την γενικότερη βιβλιογραφική τάση: Τα δομημένα δεδομένα ευνοούν συχνά τους δενδρικούς αλγόριθμους [17]. Τα δέντρα “τεμαχίζουν” εξαιρετικά αποτελεσματικά τον χώρο των χαρακτηριστικών μέσω αυστηρών κατωφλιών, χωρίς να απαιτούν τις σύνθετες ιεραρχικές μαθηματικές αναπαραστάσεις που προσπαθούν να “μάθουν” τα νευρωνικά δίκτυα .

Επίσης, η εκπαίδευση του MLP διήρκεσε 28.86 δευτερόλεπτα, απαιτώντας δηλαδή σχεδόν τον δεκαπενταπλάσιο χρόνο σε σύγκριση με τα μόλις 2.85 δευτερόλεπτα του Random Forest. Σε ένα πραγματικό περιβάλλον όπου η ταχεία επανεκπαίδευση των μοντέλων με νέα δεδομένα επιθέσεων είναι ζωτικής σημασίας για την αντιμετώπιση του Concept Drift, η κατανάλωση τόσο αυξημένων υπολογιστικών πόρων (και κατ' επέκταση οικονομικού κόστους) από τα νευρωνικά δίκτυα κρίνεται επιχειρησιακά απαγορευτική, ειδικά όταν συνοδεύεται από υποδεέστερη ακρίβεια. Συνεπώς, στο πλαίσιο της παρούσας πειραματικής διάταξης επί δομημένων χαρακτηριστικών ροής, τα δενδρικά μοντέλα αποδεικνύονται πρακτικότερα, ωστόσο, το συμπέρασμα αυτό δεν αποκλείει την αποτελεσματικότητα πιο εξειδικευμένων αρχιτεκτονικών Deep Learning (π.χ. CNN,

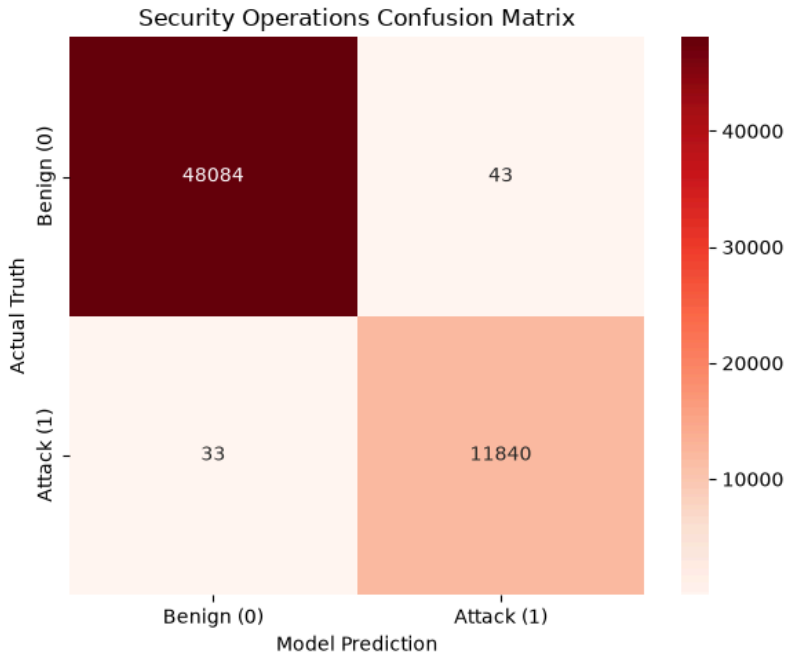
RNN) σε σενάρια ανάλυσης ακατέργαστων πακέτων ή σε περιβάλλοντα με υποστήριξη επιταχυντών GPU.

Κεφάλαιο 5: Επιχειρησιακή Αξιολόγηση και Επεξηγηματικότητα

5.1 Επιχειρησιακη αξιολόγηση σε ρεαλιστικές συνθήκες

Στην ακαδημαϊκή έρευνα της Κυβερνοασφάλειας, η αξιολόγηση ενός μοντέλου αποκλειστικά μέσω του Ποσοστού Ορθότητας (του Accuracy του δηλαδή) συνιστά μια κλασική μεθοδολογική παγίδα. Όπως αναλύθηκε εκτενώς στην Ενότητα 2.5.3 σχετικά με την ταξική ανισορροπία, η φυσιολογική κίνηση υπερτερεί συντριπτικά σε ένα πραγματικό δίκτυο. Επομένως, ένα μοντέλο που προβλέπει μονίμως την “κανονικότητα” θα επιτύχει θεωρητικά εξαιρετική ακρίβεια, έχοντας ωστόσο μηδενική πρακτική χρησιμότητα έναντι πραγματικών απειλών. Για την εξαγωγή ρεαλιστικών επιχειρησιακών συμπερασμάτων, αναλύθηκαν οι προβλέψεις του βέλτιστου μοντέλου της ενότητας 4.1 (Random Forest) προσομοιώνοντας τη λειτουργία του σε ενα Security Operation Center με ένα αντιπροσωπευτικό δείγμα 60.000 ροών του test set (48127 Benign + 11873 Attacks = 60.000), το οποίο επιλέχθηκε ώστε να προσομοιώνει την ημερήσια δραστηριότητα του δικτύου αλλά και για την υπολογιστικά αποδοτική εκτέλεση των παρακάτω δοκιμών δίχως κρασαρίσματα.

5.1.1 Πίνακας Σύγχυσης (Confusion Matrix)



Σχήμα 5.1: Confusion Matrix των αποφάσεων των συμβάντων. Θεωρώντας ότι το σύνολο δοκιμής είναι μια προσομοίωση ημερήσιας δικτυακής κίνησης, το σύστημα κλήθηκε να λάβει αποφάσεις δρομολόγησης συμβάντων.

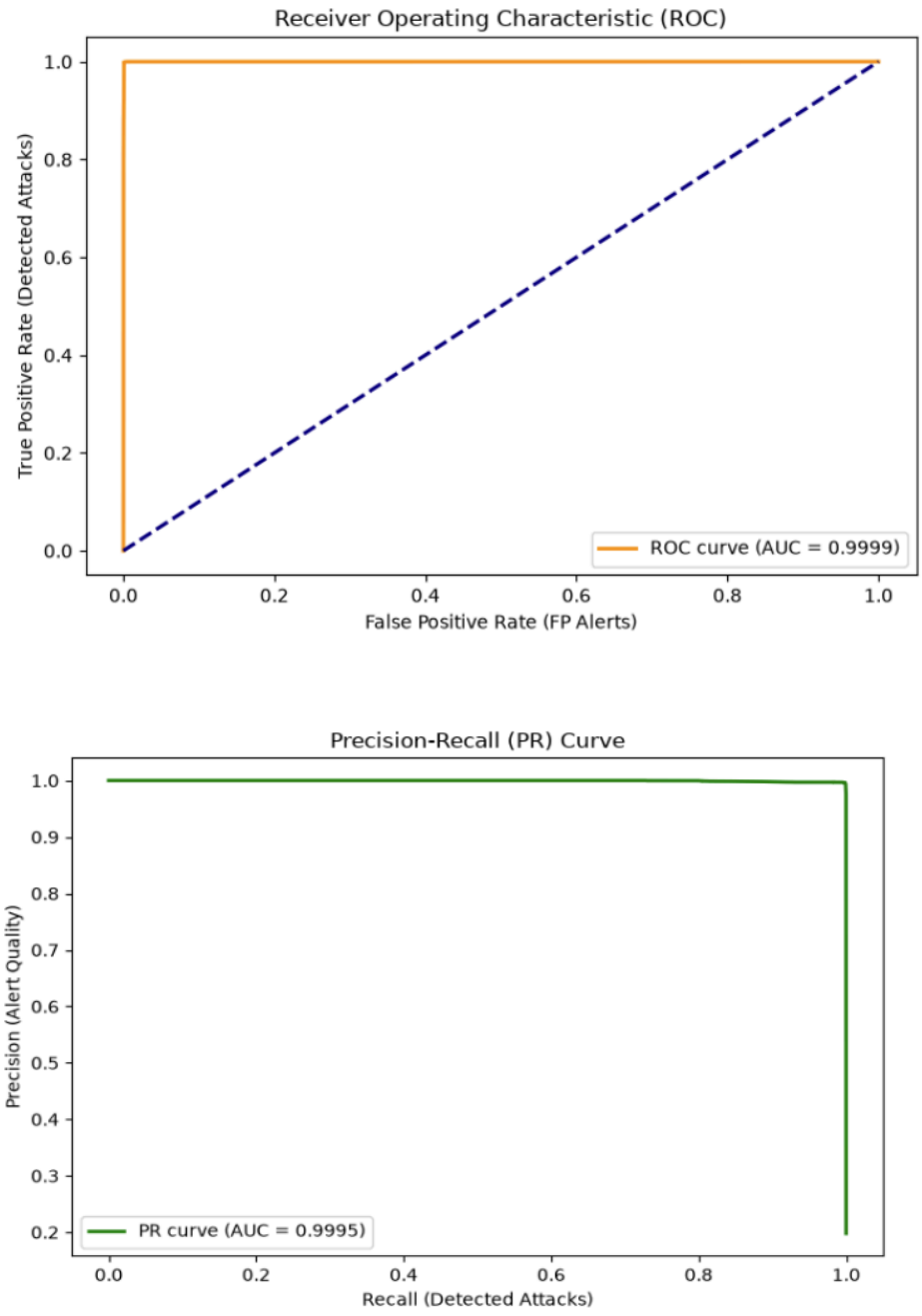
Η αξιολόγηση της ταξινομικής ικανότητας του μοντέλου βασίστηκε στη χρήση του Confusion Matrix (Σχήμα 5.1) καθώς αποτυπώνει τη διασταύρωση μεταξύ των πραγματικών ετικετών του test set και των αποφάσεων που έλαβε ο αλγόριθμος, δίνοντας μια λεπτομερή απεικόνιση των ορθών ταξινομήσεων καθώς και των επιμέρους τύπων σφάλματος.
Ειδικότερα, η συνολική απόδοση αποδομείται σε τέσσερις θεμελιώδεις συνιστώσες: τα Αληθώς Θετικά (TP), τα οποία αντιπροσωπεύουν τις πραγματικές επιθέσεις που εντοπίστηκαν επιτυχώς, τα Αληθώς Αρνητικά (TN), που αντιστοιχούν στην κανονική δικτυακή κίνηση που αναγνωρίστηκε ορθώς, τα Ψευδώς Θετικά (FP), όπου φυσιολογική κίνηση εκλήφθηκε εσφαλμένα ως απειλή, και τα Ψευδώς Αρνητικά (FN), τα οποία αντιπροσωπεύουν κακόβουλες ενέργειες που διέφυγαν της ανίχνευσης. Όπως ήδη αναφέραμε τόσο στο κεφάλαιο 1 όσο και στο 4.2.3 πολλά False Positives οδηγούν σε Alert Fatigue ενώ πολλά False Negatives υπονομεύουν την αξιοπιστία του συστήματος.

Η αναλυση του Confusion matrix μεταφράστηκε σε λειτουργικό κόστος:

- Ως πρός τα False Negatives, το μοντέλο απέτυχε να εντοπίσει τις 33 επιθέσεις. Σε ενα περιβάλλον ασφάλειας το κόστος εχει αρκετή σημασία μια και επιτρέπει σε ενα επιτιθέμενο να παραβιάσει το δίκτυο. Παρ όλα αυτα, η επιτυχης αναγνωριση των 11,840 / 11,873 δείχνει ισχυρή αποδοτικότητα.
- Ως προς τα False Positives, και το Alert Fatigue, οι 43 εσφαλμένοι συναγερμοί επί συνόλου 48.127 κανονικών ροών αντιστοιχούν σε False Positive Rate μόλις 0.09%. Παράλληλα, επί του συνόλου των 11.883 παραγόμενων συναγερμών, το False Discovery Rate είναι μόλις 0.36%, πράγμα που καθησυχάζει μια και το υπόλοιπο 99.64% των ειδοποιήσεων αφορά πραγματικά περιστατικά.

Για την αξιολόγηση της σταθερότητας του μοντέλου υπο διαφορετικά Thresholds κατασκευάστηκαν και παρατηρήθηκαν οι καμπύλες ROC -για τη σχέση μεταξύ επιτυχημένων εντοπισμών και εσφαλμένων συναγερμών- και Precision Recall για τη ποιότητα των παραγόμενων συναγερμών.
Οι μεγάλες τιμές στο εμβαδόν κάτω απ' την καμπύλη που προσεγγίζουν το 1.0 και στα δύο γραφήματα, μας επιβεβαιώνουν ότι το μοντέλο έχει βελτιστοποιηθεί στο αυστηρό γεωμετρικό διαχωρισμό μεταξύ της κανονικής κίνησης και επιθέσεων αντι απλώς ένα τυχαίο σταθερό κατώφλι. Σε πρακτικά σενάρια αυτό δίνει τη δυνατότητα για δική μας

προσαρμογή για την ευαισθησία του συστήματος ανάλογα με το τρέχον επίπεδο απειλής χωρίς τη θυσία ποιότητας ανίχνευσης.



Σχήμα 5.2: Καμπύλες Λειτουργικού Χαρακτηριστικού Δέκτη (ROC) και Ακρίβειας-Ανάκλησης (Precision-Recall) για την αξιολόγηση των κατωφλιών.

5.2 Επεξηγηματικότητα και Διαφάνεια Αποφάσεων (Explainable AI)

Παρά το γεγονός οτι σύγχρονοι δενδρικοί ταξινομητές μηχανικής μάθησης επιτυγχάνουν ποσοστά ανιχνευσης πάνω απο 95% σε ελεγχόμενα περιβάλλοντα, η επιχειρισιακή τους χρησιμότητα σε ένα SoC συχνά δεν είναι το ίδιο καλή μια και ο πολύπλοκος και μη-γραμμικός τρόπος λειτουργίας τους (όπως εξηγήθηκε στην Ενότητα 4.1.2) τους καθιστά συχνά "μαύρα κουτιά" (black boxes) για τον τελικό χρήστη. Σύμφωνα με πρόσφατες μελέτες [3], η απόδοση ενός συστήματος ανίχνευσης εισβολών δεν περιορίζεται απο την ακρίβεια του αλλα απ τον ρυθμό απόκρισης του ανθρώπου ο οποίος είναι υπεύθυνος για αυτα. Οταν οι αναλυτές καλούνται να διαχειριστούν ειδοποιήσεις υπο τη πίεση του χρόνου, τείνουν να αγνοούν συστηματικα τις αποφασεις αλγορίθμων λόγω έλλειψης διαφάνειας.
Συνεπώς η επεξηγηματική τεχνητή νοημοσύνη παίζει σημαντικό ρόλο για τη δημιουργία σχέσης και εμπιστοσύνης για την αποδοχή των μοντέλων.

Η παραδοσιακή μετρική feature importance (η οποία χρησιμοποιήθηκε στο Κεφάλαιο 3.2 για την επιλογή χαρακτηριστικών) είναι πολύ καλή όταν απαιτείται ένα global explanation σε μοντέλα, κατευθύνοντας προς τα πιο χρήσιμα χαρακτηριστικά, κάτι όμως που αποτελεί περιοριστικό σε περιπτώσεις εξέτασης περιστατικών ασφαλείας στα οποία ο αναλυτής χρειάζεται local explanation δηλαδή να γνωρίζει ποιά χαρακτηριστικά συγκεκριμένα πυροδότησαν τον συναγερμό για το εκάστοτε πακέτο [4].

Για το σκοπό αυτό η βιβλιογραφία προκρίνει δύο κύριες προσεγγίσεις:

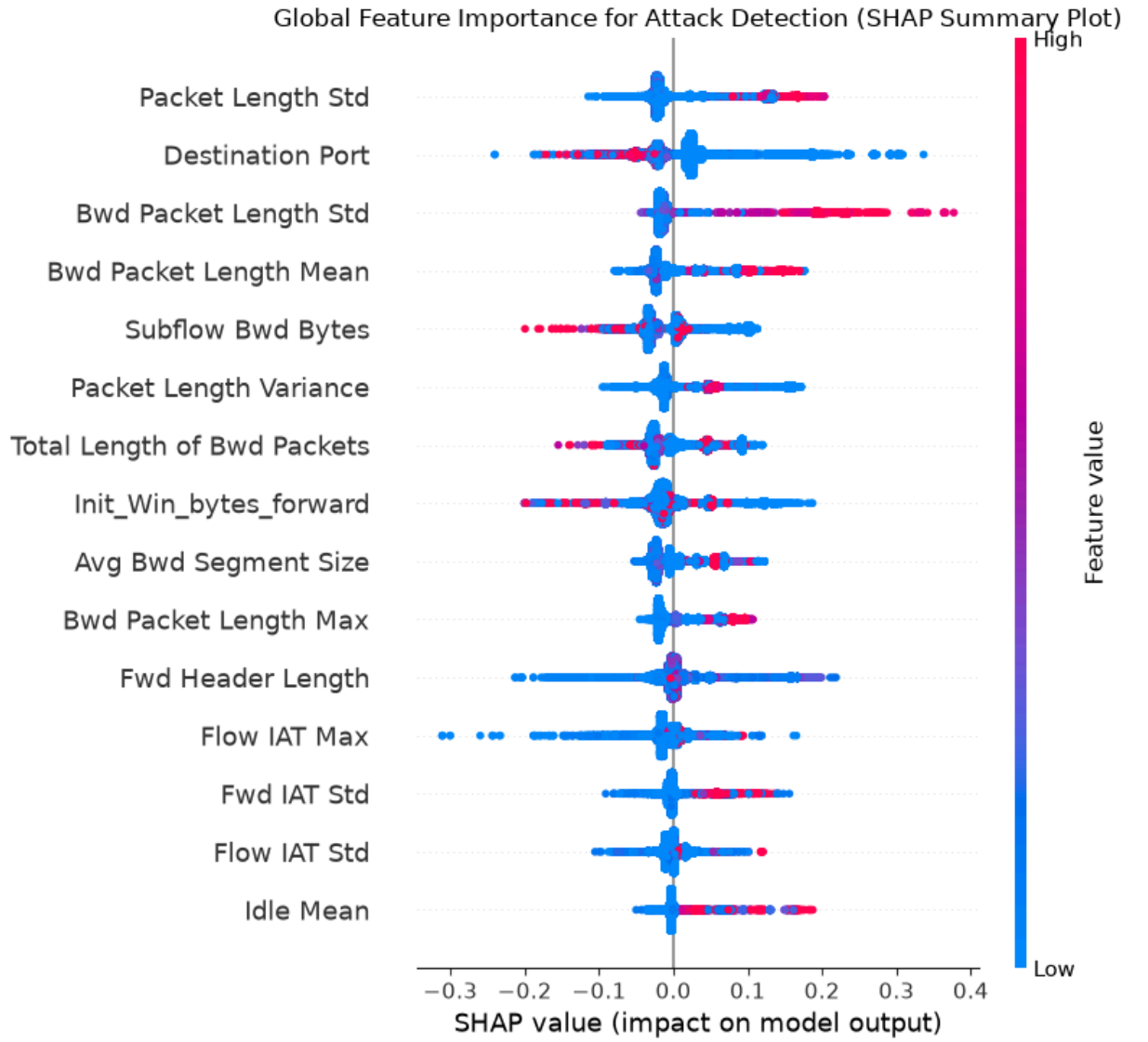
- LIME (Local Inerpretable Model-agnostic Explanations): λειτουργεί κατασκευάζοντας ένα απλό γραμμικό μοντέλο-υποκατάστατο τοπικά γύρω απ τη πρόβλεψη που εξετάζουμε. Αν και γρήγορο, συχνά πάσχει από μαθηματική αστάθεια, καθώς μικρές αλλαγές στο δείγμα μπορεί να παράγουν αντιφατικές επεξηγήσεις.

- SHAP (SHapley Additive exPlanations): Βασίζεται στη θεωρία παιγνίων. Στην παρούσα εργασία επιλέχθηκε το SHAP και συγκεκριμένα ο αλγόριθμος TreeExplainer, καθώς υπολογίζει την ακριβή, additive feature attribution κάθε μεμονωμένου χαρακτηριστικού στην απόκλιση της πρόβλεψης από τον μέσο όρο του μοντέλου.

5.2.1 Τεχνική Υλοποίηση SHAP και Προκλήσεις

Η πρακτική εφαρμογή του SHAP αποτέλεσε σημαντική προγραμματιστική πρόκληση, Αρχικά η προσπάθεια εξαγωγής τιμών SHAP για το σύνολο των εγγραφών του Test Set οδήγησε σε εξάντληση των πόρων του συστήματος (approx. run time before shutting down: 16272 sec -4,5 hours), οπότε για να καταστεί εφικτός ο υπολογισμός χωρίς αλλοίωσης στατιστικής εγκυρότητας, εφαρμόστηκε τυχαία αντιπροσωπευτική δειγματοληψία 50.000 flows. Ένα επιπλέον ζήτημα ήταν η διαχείριση της 3D δομής εξόδου (δείγματα x χαρακτηριστικά x 15 κλάσεις) που επιστρέφει ο TreeExplainer για το Random Forest. Επειδή το μοντέλο αναγνωρίζει 15 διαφορετικές κατηγορίες (όπου η κλάση 0 -μηδέν- αντιστοιχεί στη Benign), ενώ η επιχειρησιακή αξιολόγηση του Κεφαλαίου 5 εξετάζει τη δυαδική απόφαση συναγερμού P(attack)=1-P(Benign), ο κώδικας (μέσω της extract_1d_attack) ρυθμίστηκε ώστε να εξάγει την ακριβώς αντίθετη επιρροή της κλάσης 0 (-shap_values[:, :, 0]). Με τον τρόπο αυτό, οι θετικές τιμές SHAP αντιστοιχούν αυστηρά στην αύξηση της συνολικής πιθανότητας επίθεσης.

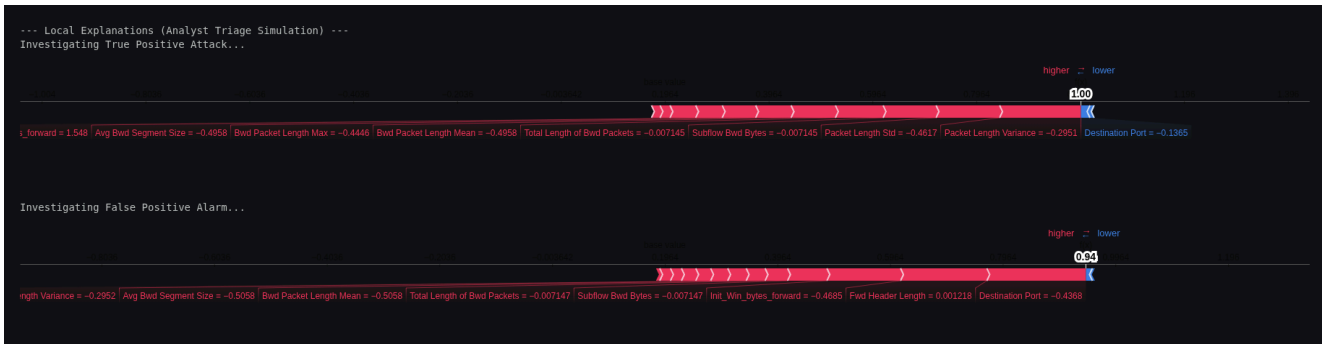
Όσον αφορά την απενεργοποίηση του εσωτερικού ελέγχου της βιβλιοθήκης (check_additivity=False), αυτή η ενέργεια έγινε συνειδητά διότι η μετατροπή των δεδομένων σε μορφή float32 για εξοικονόμηση μνήμης RAM προκαλούσε απειροελάχιστες αποκλίσεις στρογγυλοποίησης στα δεκαδικά ψηφία. Αυτές οι μικρο-διαφορές ενεργοποιούσαν ψευδώς το σφάλμα της βιβλιοθήκης, χωρίς ωστόσο να αλλοιώνουν την πραγματική ιεράρχηση των χαρακτηριστικών. Τέλος, για την τοπική επεξήγηση μεμονωμένων αποφάσεων, επιλέχθηκε η αναπαράσταση μέσω Local Bar Plots αντί των προεπιλεγμένων διαδραστικών Force Plots, καθώς τα δεύτερα παρουσίασαν οπτικά σφάλματα όταν η βεβαιότητα του μοντέλου προσεγγίζει το 100% πράγμα που μπορεί να παρερμηνευτεί για το αποτέλεσμα της ανάλυσης.



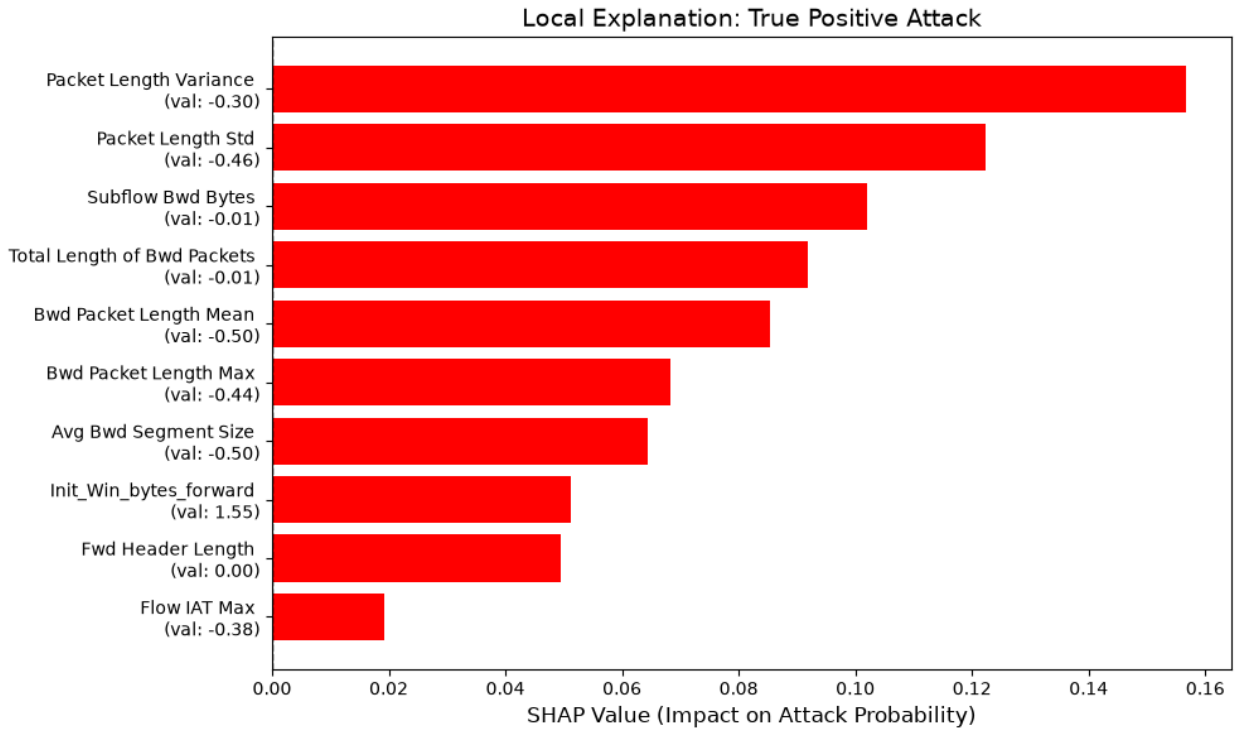
Σχήμα 5.3: Συνοπτικό γράφημα SHAP. Η θέση στον οριζόντιο άξονα δείχνει την επιρροή στο αποτέλεσμα (δεξιά αυξάνει την πιθανότητα επίθεσης), ενώ το χρώμα (μπλε έως φούξια) υποδηλώνει την κανονικοποιημένη τιμή του χαρακτηριστικού. Π.χ για το Destination Port οι χαμηλές τιμές θυρών (όπως η 21, 22, 80 - μπλε χρώμα) αυξάνουν δραματικά την πιθανότητα να είναι κάτι Επίθεση. Αντίθετα, οι ψηλές/τυχαίες θύρες (κόκκινες τελείες, π.χ. θύρα 50.000) βρίσκονται κυρίως αριστερά, ωθώντας προς την κανονική κίνηση.

Αποτελέσματα:

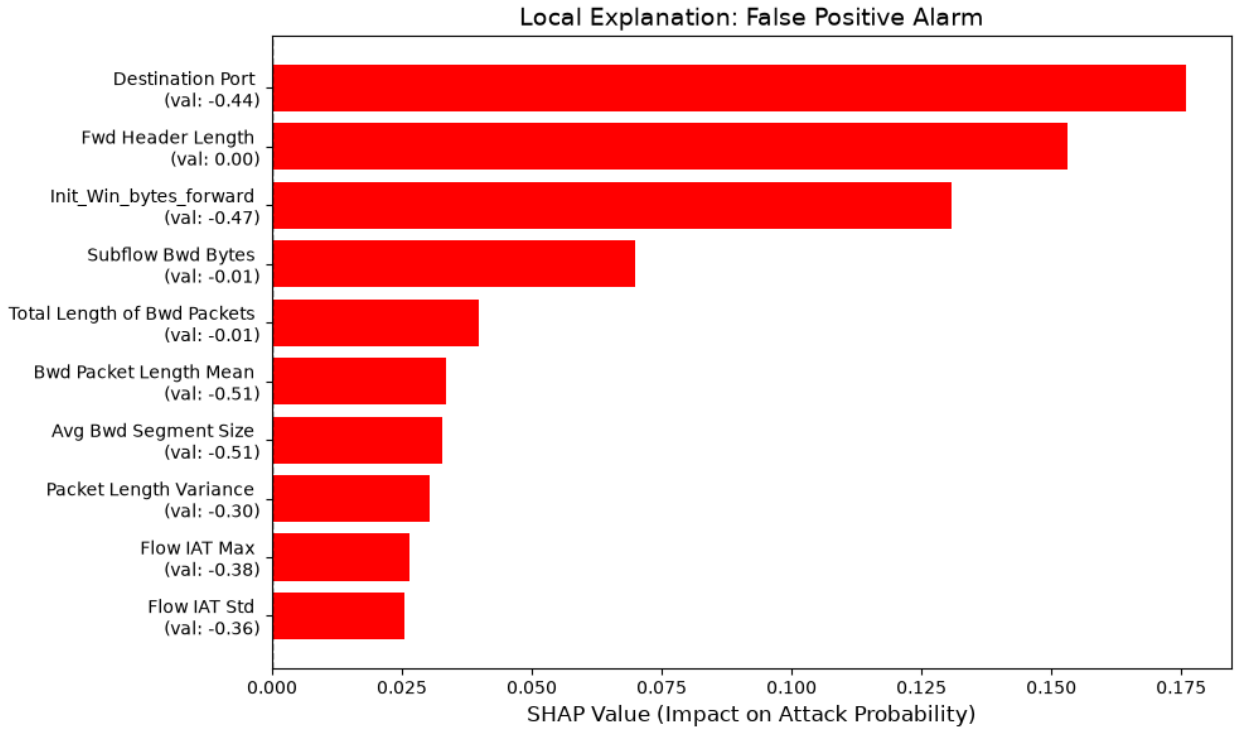
Η ανάλυση του Σχήματος 5.3 επιβεβαιώνει τη θεωρία που αναπτύχθηκε στην Ενότητα 3.3. Το μοντέλο έχει μάθει να συσχετίζει τόσο τις υψηλές τιμές (φούξια χρώμα) σε χαρακτηριστικά διακύμανσης μεγέθους όπως τα Bwd Packet Length Std, Packet Length Std και Bwd Packet Length Mean, όσο και συγκεκριμένες χαμηλές τιμές (μπλε χρώμα) σε μεταβλητές όπως το Destination Port, με την κακόβουλη δράση. Αυτό ταιριάζει απόλυτα με τη φύση των επιθέσεων DDoS και Botnets, οι οποίες χαρακτηρίζονται από επαναλαμβανόμενα μεγέθη πακέτων και αφύσικους ρυθμικούς χρόνους άφιξης.



Σχήμα 5.4.1: Αρχική προσπάθεια τοπικής επεξήγησης μέσω διαδραστικών Force Plots. Λόγω της βεβαιότητας του μοντέλου που αγγίζει το 100%, παρατηρείται έντονη οπτική συμπίεση των μεταβλητών.



Σχήμα 5.4.2: Τοπική επεξήγηση μιας True Positive επίθεσης. Οι κόκκινες μπάρες απεικονίζουν με σαφήνεια τα χαρακτηριστικά που συνέβαλαν στην ταξινόμηση της ροής ως επίθεση.



Σχήμα 5.4.3: Τοπική επεξήγηση ενός False Positive συναγερμού. Οι κόκκινες μπάρες υποδεικνύουν τα στοιχεία που ξεγέλασαν το μοντέλο. Βλέπουμε ότι η τιμή του Destination Port (-0.44) σημαίνει ότι πρόκειται για χαμηλή θύρα. Ο έμπειρος αναλυτής θα δεί ότι βάρεσε συναγερμός κυρίως λόγω αυτού οπότε δε θα μπλοκάρει τυφλά την IP και θα το ψάξει παραπάνω μια και χαμηλές θύρες μπορεί να χρησιμοποιούνται τόσο από χρήστες όσο και από Hackers.

Έπειτα προσομοιώθηκε η δουλειά ενός αναλυτή αναλύοντας συγκεκριμένα μεμονωμένα περιστατικά μέσω των τοπικών bar charts τους.

Στο πρώτο γράφημα (Σχήμα 5.4.2) αναλύεται μια True Positive ανίχνευση επίθεσης. Όπως αποτυπώνεται από τις κόκκινες μπάρες (προς τα δεξιά άρα θετική SHAP Value), χαρακτηριστικά που αφορούν τη διακύμανση και το μέγεθος των πακέτων (Packet Length Variance, Packet Length Std) ώθησαν δυναμικά την πρόβλεψη προς τον συναγερμό. Αξίζει να σημειωθεί η ισχύς των μη γραμμικών δενδρικών αλγορίθμων (βλ. Ενότητα 4.1.2): Το Packet Length Variance είχε αρνητική αρχική τιμή (Z-score: -0.30, άρα χαμηλή διακύμανση), ωστόσο το μοντέλο αξιολόγησε αυτή τη χαμηλή τιμή -ενδεικτική μιας αυτοματοποιημένης επίθεσης με σταθερό μέγεθος πακέτων- ως κρίσιμη ένδειξη επίθεσης, αποδίδοντάς της τη μεγαλύτερη θετική επιρροή. Ένας αναλυτής του SOC, βλέποντας μέσω του SHAP ότι ο συναγερμός βασίζεται σε ένα τόσο ισχυρό στατιστικό μοτίβο ανώμαλου όγκου, αποκτά την απαραίτητη εμπιστοσύνη στην απόφαση του αλγορίθμου, προχωρώντας σε άμεσο block της κακόβουλης IP χωρίς περαιτέρω χάσιμο χρόνου.

Αντίθετα, στο δεύτερο γράφημα (Σχήμα 5.4.3) αναλύεται ένας False Positive συναγερμός, δηλαδή μια ροή που από τις ετικέτες του dataset γνωρίζουμε ότι ήταν κανονική, αλλά το μοντέλο την κατέταξε ως επίθεση. Το χαρακτηριστικό με τη μεγαλύτερη συμβολή στον συναγερμό ήταν το Destination Port (με αρνητική τιμή Z-score -0.44, υποδηλώνοντας χαμηλή θύρα όπως π.χ η 80 ή η 443). Το μοντέλο είχε μάθει (όπως φάνηκε στο Σχήμα 5.3) ότι πολλές επιθέσεις στοχεύουν αυτές τις χαμηλές θύρες. Έτσι, υπερεκτίμησε τη σημασία της θύρας και καταδίκασε τη νόμιμη κίνηση που απλώς μοιραζόταν την ίδια θύρα. Το εύρημα αυτό επιβεβαιώνει επίσης την κριτική ανάλυση της Ενότητας 3.3 περί dataset shortcuts της μεταβλητής Destination Port. Σε ένα πραγματικό SOC, ο αναλυτής βλέποντας ότι ο συναγερμός βασίστηκε κυρίως σε μια κοινή θύρα (και όχι σε ξεκάθαρα κακόβουλα μοτίβα όγκου), κατανοεί την αβεβαιότητα του μοντέλου και μπορεί να ερευνήσει περαιτέρω πριν προχωρήσει σε τυφλό αποκλεισμό.

5.3 Επιθέσεις Αποφυγής και Ευπάθεια

Οι αλγόριθμοι Μηχανικής Μάθησης, παρά την υψηλή τους απόδοση σε ελεγχόμενα περιβάλλοντα, είναι εγγενώς ευάλωτοι απέναντι σε στοχευμένες παρεμβάσεις. Προκειμένου να αξιολογηθεί η επιχειρησιακή ευθραυστότητα του μοντέλου Random Forest που αναπτύχθηκε, εκτελέστηκε μια προσομοίωση επιθετικού ελέγχου (εφεξής Red Teaming) βασισμένη στις αρχές της Adversarial Machine Learning υπο αυστηρούς περιορισμούς δικτυακού πεδίου.

Αντί τυφλού θορύβου, εφαρμόστηκε μετατόπιση των 8 ελεγχόμενων χαρακτηριστικών κατά λ = 80% προς τη διάμεσο της κανονικής κίνησης (το Benign profile - κάνοντάς τα όσο πιο καλοηθής μπορούμε να “φαίνονται”) με προσθήκη μικρής στοχαστικής διακύμανσης N(0, 0.15) (seed=42), περιορίζοντας τις τελικές τιμές εντός των φυσικών ελαχίστων και μεγίστων ορίων του συνόλου δεδομένων ώστε να μην υπάρχει πρόβλημα με μη ρεαλιστικές (πχ αρνητικές) τιμές.

- ➔ Ελεγχόμενα Χαρακτηριστικά (8) (Παρεμβάσεις που ελέγχει ο πελάτης / επιτιθέμενος)
  ['Fwd IAT Std', 'Flow IAT Std', 'Flow IAT Max', 'Idle Mean', 'Packet Length Std', 'Packet Length Variance', 'Init_Win_bytes_forward', 'Fwd Header Length']

- ➔ Αμετάβλητα Χαρακτηριστικά (7) (αφού ο επιτιθέμενος δεν ελέγχει τις απαντήσεις του server ούτε μπορεί να αλλάξει τη θύρα που στοχεύει:
  ['**Bwd Packet Length Std', 'Destination Port', 'Bwd Packet Length Mean', 'Bwd Packet Length Max', 'Total Length of Bwd Packets', 'Subflow Bwd Bytes', 'Avg Bwd Segment Size**']

```
Original Detected Attacks (Baseline True Positives): 11,840
Attacker-Controlled Features (8): ['Fwd IAT Std', 'Flow IAT Std', 'Flow IA
Locked Features (7): ['Bwd Packet Length Std', 'Destination Port', 'Bwd Pa

Testing model robustness against Constrained Evasion Attack...

--- Constrained Evasion Attack Results ---
Attacks that bypassed the model (False Negatives): 6,631 out of 11,840
Detection Degradation Rate (Evasion Success Rate): 56.01%
```

Σχήμα 5.5: Αποτελέσματα Evasion Attack Μετρήσεων

```
--- Per-Attack Evasion Breakdown ---
                        Detected_Baseline  Evaded_Model  Evasion_Rate (%)
Attack_Type
Bot                                    34            32             94.12
DDoS                                 2772          1041             37.55
DoS GoldenEye                         191            58             30.37
DoS Hulk                             4863          1564             32.16
DoS Slowhttptest                      115           108             93.91
DoS slowloris                         132           129             97.73
FTP-Patator                           157           124             78.98
Heartbleed                              1             1            100.00
PortScan                             3435          3434             99.97
SSH-Patator                           118           118            100.00
Web Attack  Brute Force                18            18            100.00
Web Attack  XSS                         4             4            100.00
```

Σχήμα 5.6: Πίνακας αποτελεσμάτων μετρικών ανα επίθεση. Η πρώτη στήλη περιγράφει το πλήθος των επιθέσεων που εντοπίστηκαν αρχικά από το μοντέλο. Η δεύτερη περιγράφει πόσες εξ αυτών απέφυγαν την ανιχνευση μετά τη παραμόρφωση, ενώ η τρίτη το ποσοστό αποφυγής ανίχνευσης του μοντέλου. Λείπουν τα SQL Injection και Infiltration καθώς στο δείγμα δεν υπήρχαν true positives.

Τα αποτελέσματα του Σχήματος 5.5 επιβεβαιώνουν ότι, ακόμη και όταν ο επιτιθέμενος δεν έχει κανέναν έλεγχο επί των Bwd features ή της θύρας προορισμού, η στοχευμένη προσαρμογή του χρονισμού και του μεγέθους των εξερχόμενων πακέτων αρκεί για να παρακάμψει σε σημαντικό βαθμό τον ταξινομητή. Επιπλέον, η ανάλυση ανά κατηγορία επίθεσης (Σχήμα 5.6 - όπου περιλαμβάνονται οι 12 κατηγορίες απειλών που κατέγραψαν τουλάχιστον ένα αρχικό True Positive στο δείγμα αξιολόγησης) αποκαλύπτει μια σαφή διαφοροποίηση: οι επιθέσεις των οποίων η ανίχνευση βασιζόταν κυρίως στον ρυθμό αποστολής και τα χαρακτηριστικά πελάτη, όπως το PortScan

(99.97% evasion), το DoS slowloris (97.73%), το Bot (94.12%) και το SSH-Patator (100%), παρακάμπτουν σχεδόν πλήρως τον ταξινομητή. Αντίθετα, οι ογκομετρικές επιθέσεις που προδίδονται από τον όγκο απόκρισης, όπως το DoS GoldenEye (30.37%), το DoS Hulk (32.16%) και το DDoS (37.55%), παραμένουν σημαντικά ανθεκτικότερες [5] [6].

Κεφάλαιο 6: Συμπεράσματα και Επιχειρησιακή Ενσωμάτωση

6.1 Το Χάσμα μεταξύ Academic και Πραγματικού Περιβάλλοντος Προσαρμογής

Ένα από τα σημαντικότερα προβλήματα στη βιβλιογραφία της κυβερνοασφάλειας είναι ότι τα περισσότερα ακαδημαϊκά μοντέλα αποτυγχάνουν κατά τη μετάβασή τους σε πραγματικά περιβάλλοντα παραγωγής [7]. Αυτό οφείλεται στο γεγονός ότι τα μοντέλα αυτά εκπαιδεύονται, αξιολογούνται και εγκαταλείπονται εντός στατικών αρχείων (πχ Jupyter Notebooks και CSV δεδομένα όπως έγινε και σε αυτή την έρευνα). Αντίθετα, ένα σύγχρονο SOC απαιτεί δυναμικές αρχιτεκτονικές που διαχειρίζονται ροές δεδομένων σε πραγματικό χρόνο και όχι με παρτίδες, αντιμετωπίζοντας διαρκείς αλλαγές στη συμπεριφορά του δικτύου.

Για να καταστεί το βέλτιστο μοντέλο Random Forest της παρούσας μελέτης επιχειρησιακά εκμεταλλεύσιμο, σχεδιάστηκε η παρακάτω ρεαλιστική αρχιτεκτονική ενσωμάτωσης.

6.2 Deployment Note

Το μοντέλο αυτό δεν λειτουργεί αυτόνομα, αλλά εντάσσεται ως μικρουπηρεσία στο ευρύτερο οικοσύστημα ανίχνευσης και απόκρισης του δικτύου (NDR - Network Detection and Response).

Η προτεινόμενη αρχιτεκτονική ροής δεδομένων ορίζεται από τα εξής διαδοχικά στάδια:

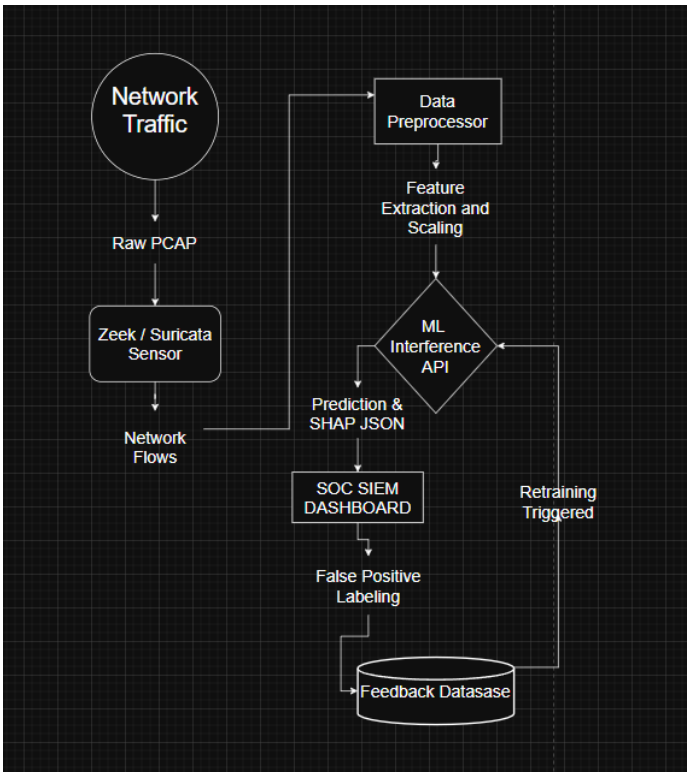
1. Η Συλλογή και Ανάλυση (PCAP/Flow Source): Αισθητήρες επιθεώρησης δικτύου, όπως το Zeek ή το Suricata, τοποθετούνται στρατηγικά στους δρομολογητές του οργανισμού. Αυτά τα εργαλεία αναλύουν την ακατέργαστη κίνηση (raw PCAP) και την ομαδοποιούν σε συνεδρίες (network flows) σε πραγματικό χρόνο-

(περισσότερα για αυτό στη συνέχεια).

2. Η Προεπεξεργασία (Preprocessing & Feature Extraction): Μια ενδιάμεση υπηρεσία (π.χ. σε python) παραλαμβάνει τα logs του Zeek/Suricata, καθαρίζει τις NaN τιμές, κανονικοποιεί τα δεδομένα και εξάγει αποκλειστικά τα 15 επιλεγμένα χαρακτηριστικά (όπως έγινε στο κεφάλαιο 3), δημιουργώντας παράλληλα τα κυλιόμενα time windows που απαιτούνται για την ανίχνευση DDoS.

3. Η Επεξηγησιμότητα (Model Inference & XAI): Τα καθαρά πλέον δεδομένα τροφοδοτούνται στο εκπαιδευμένο Random Forest μέσω ενός REST API. Για κάθε ροή που ταξινομείται ως "Επίθεση", πυροδοτείται αυτόματα ο αλγόριθμος SHAP (κεφάλαιο 5.2), υπολογίζοντας τους τοπικούς παράγοντες που οδήγησαν στην απόφαση.

4. Η Δρομολόγηση Ειδοποιήσεων (SIEM Integration & Alerting): Η τελική πρόβλεψη (μαζί με το JSON των τιμών SHAP) δεν παραμένει σε κάποιο αυτόνομο περιβάλλον, αλλά αποστέλλεται στο κεντρικό SIEM (σύστημα διαχείρησης συμβάντων) της εταιρείας για ανάλυση.



Σχήμα 6.1: Προτεινόμενη Αρχιτεκτονική ενσωμάτωσης της Μηχανικής Μάθησης σε περιβάλλον SOC (Data Pipeline & Feedback Loop).

Μία από τις μεγαλύτερες προκλήσεις κατά τη μετάβαση από το ακαδημαϊκό περιβάλλον (όπου χρησιμοποιήθηκε το εργαλείο CICFlowMeter) στην παραγωγή, είναι η αντιστοίχιση των χαρακτηριστικών στα logs των πραγματικών αισθητήρων όπως το Zeek ή το Suricata. Πολλά από τα στατιστικά χαρακτηριστικά του μοντέλου δεν καταγράφονται απευθείας ως έτοιμες μεταβλητές, αλλά απαιτούν δυναμικό υπολογισμό σε επίπεδο μνήμης πριν τροφοδοτηθούν στο μοντέλο. Ο Πίνακας 6.1 αποτυπώνει την αρχιτεκτονική αντιστοίχισης των 15 βέλτιστων χαρακτηριστικών του μοντέλου μας με τα πραγματικά συστήματα

Κατηγορία	Χαρακτηριστικά Μοντέλου (CICFlowMeter)	Αντιστοίχιση σε Zeek / Suricata	Υπολογιστική Απαίτηση σε πραγματικό χρόνο SOC	Μονάδα Μέτρησης
Βασική Ροή	Destination Port	Zeek: conn.log (id.resp_p) Suricata: eve.json (dest_port)	Άμεση εξαγωγή χωρίς έξτρα επεξεργασία	Ακέραιος 0-65535, Per-Flow
Όγκος & Μέγεθος	Total Length of Bwd Packets, Subflow Bwd bytes, Bwd Packet Length (Mean, Std, Max), Packet Length (Std, Variance), Avg Bwd Segment Size	Zeek: conn.log (resp_bytes, resp_pkts) Suricata: eve.json (flow_bytes_toclient)	Απαιτείται μηχανή συνάθροισης (π.χ. Kafka / python buffer) για τον ενδιάμεσο υπολογισμό μέσης τιμής, διακύμανσης και μέγιστου μεγέθους εντός χρονικού παραθύρου	Bytes, Παράθυρο Ροής / W = 50
Χρόνος & IAT	Flow IAT Max, Fwd IAT Std, Flow IAT Std, Idle Mean	Zeek/Suricata: Αναχώρηση από timestamps διαδοχικών πακέτων της ίδιας πεντάδας.	Custom Zeek Script ή in-memory υπολογισμό του Inter-Arrival Time μεταξύ διαδοχικών πακέτων της	Μετατροπή από sec του Zeek σε microseconds μs του CICFlowMeter,

			ροής.	Παράθυρο Ροής
Επικεφαλίδες	Init_Win_bytes_forward, Fwd Header Length	Zeek: orig_tcp_window Suricata: tcp.window	Άμεση ανάγνωση των TCP Headers (απαιτείται ενεργοποίηση επιλογής καταγραφής TCP παραμέτρων στον αισθητήρα).	Bytes, Per flow

Πίνακας 6.1: Πίνακας Αντιστοίχισης Χαρακτηριστικών CICFlowMeter σε δεδομένα πραγματικού χρόνου (Zeek/Suricata).

6.3 Διαχείριση Κύκλου Ζωής και Ανατροφοδότηση (MLOps & Feedback Loop)

Η μετάβαση στην παραγωγή φυσικά δεν σηματοδοτεί το τέλος της ανάπτυξης του λογισμικού αυτού. Όπως αποδείχθηκε στο Κεφάλαιο 5.3 (Επιθέσεις Αποφυγής), αλλά και λόγω των φυσιολογικών τεχνολογικών αλλαγών στις υποδομές ενός δικτύου, η απόδοση του αλγορίθμου αναπόφευκτα θα υποβαθμιστεί σταδιακά (φαινόμενο Model Drift).

Για τη διασφάλιση της μακροχρόνιας ανθεκτικότητας, η αρχιτεκτονική επιβάλλεται να περιλαμβάνει διαδικασίες Human-in-The-Loop [8]. Όταν οι αναλυτές αξιολογούν τα παραγόμενα alerts στο SIEM, διατηρούν τη δυνατότητα να επισημάνουν έναν συναγερμό ως "False Positive" ή "True Positive". Αυτή η επισήμανση αποθηκεύεται αυτόματα σε μια βάση Feedback Database. Όταν συγκεντρωθεί επαρκής αριθμός διορθωμένων -από τον άνθρωπο- δειγμάτων, το σύστημα επανεκπαιδεύεται αυτόματα. Η προσέγγιση αυτή δημιουργεί ένα συνεχώς εξελισσόμενο ανοσοποιητικό σύστημα, το οποίο προσαρμόζεται δυναμικά στις νέες απειλές και ελαχιστοποιεί προοδευτικά την κόπωση ειδοποιήσεων των αναλυτών.

Κεφάλαιο 7: Εγχειρίδιο αναπαραγωγιμότητας και Λογισμικό

Για τη διασφάλιση της επιστημονικής διαφάνειας και την πλήρη αναπαραγωγιμότητα των πειραμάτων της παρούσας πτυχιακής εργασίας, δημιουργήθηκε το αντίστοιχο περιβάλλον ανάπτυξης. Όλος ο κώδικας έχει γραφτεί και εκτελεστεί σε περιβάλλον Jupyter Notebook.

7.1 Απαιτήσεις Λογισμικού (Software Prerequisites)

Για την απρόσκοπτη εκτέλεση του κώδικα, το περιβάλλον πρέπει να πληροί τις κάτωθι προδιαγραφές, όπως αυτές διατυπώθηκαν κατά τη φάση της εκπαίδευσης:

- **Γλώσσα Προγραμματισμού:** Python 3.11+ (το πειραματικό πλάισιο χρησιμοποίησε 3.12 εντός Visual Studio Code)
- **Βασικές Βιβλιοθήκες Ανάλυσης:** pandas (έκδοση 2.3.3), numpy (έκδοση 2.3.5), matplotlib, seaborn.
- **Μηχανική Μάθηση:** scikit-learn (έκδοση 1.8.0) για την προεπεξεργασία (StandardScaler, LabelEncoder) και την εκπαίδευση των μοντέλων.
- **Επεξηγηματικότητα:** shap (έκδοση 0.51.0) για την παραγωγή των Force και Summary Plots.

Το αρχείο του κώδικα περιλαμβάνει τα απαραίτητα Installs σε περίπτωση που απουσιάζουν απο το virtual Environment.

Οι ερευνητές που επιχειρούν να αναπαραγάγουν αυτόν τον κώδικα καλό είναι να χρησιμοποιήσουν απομονωμένα virtual environments.

1. Ένα εικονικό περιβάλλον πρέπει να δημιουργηθεί στον root κατάλογο του έργου χρησιμοποιώντας την εντολή: **python3 -m venv .venv**
2. Το περιβάλλον πρέπει να ενεργοποιηθεί πριν από την εγκατάσταση των εξαρτήσεων:
   source .venv/bin/activate για Linux / MacOs

   \.venv\Scripts\activate για Windows

   Αν δεν τρέχει επειδή λέει running scripts is disabled on this system, run:

```
Set-ExecutionPolicy -ExecutionPolicy RemoteSigned -Scope CurrentUser
```

3. Εντός του VS Code, ο kernel του Jupyter πρέπει να αντιστοιχιστεί ρητά στη διαδρομή αυτού του εικονικού περιβάλλοντος (**./.venv/bin/python**) και όχι στην καθολική Python του συστήματος.

Η εκτέλεση ενσωματωμένων εγκαταστάσεων πακέτων (π.χ. **%pip install**) εντός των κελιών του Jupyter Notebook αποτυγχάνει εάν λείπει το πακέτο **ipykernel**, προκαλώντας ένα επαναλαμβανόμενο σφάλμα στο VS Code σχετικά με εξαρτήσεις που λείπουν.

```
%pip install scikit-learn
%pip install shap
%pip install numpy
%pip install pandas
%pip install matplotlib
%pip install seaborn
```

Πρέπει να εγκατασταθεί είτε μέσω του διαχειριστή πακέτων του συστήματος (**sudo apt install python3-ipykernel**) είτε να εισαχθεί απευθείας στο ενεργό εικονικό περιβάλλον (**pip install ipykernel**) μέσω του τερματικού ***πριν*** εκτελεστούν οποιεσδήποτε εντολές "magic" ή κώδικας του notebook. Μετά την εγκατάσταση, απαιτείται επανεκκίνηση του kernel.

Extra Help: Σε περίπτωση crash λόγω μνήμης, οι "ορφανές" background processes πρέπει να τερματιστούν χειροκίνητα χρησιμοποιώντας την εντολή τερματικού **pkill -f python** πριν από την επαναφόρτωση του παραθύρου του VS Code.

7.2 Λήψη, δομή δεδομένων και cross platform λειτουργικότητα

Η ανάλυση προϋποθέτει τη λήψη του επίσημου συνόλου δεδομένων "CIC-IDS2017 Intrusion Detection Evaluation Dataset" από το Canadian Institute for Cybersecurity [9]. Τα αρχεία μορφής CSV, περιέχουν τις δικτυακές ροές και πρέπει να τοποθετηθούν αυτούσια εντός ενός κεντρικού φακέλου με την ονομασία **TrafficLabelling**.

Προκειμένου να διασφαλιστεί η πλήρης φορητότητα (portability) και η αναπαραγωγιμότητα του πειράματος ανεξαρτήτως λειτουργικού συστήματος (Windows, Linux, macOS), η διαχείριση των διαδρομών των αρχείων (path handling) στον πηγαίο κώδικα δεν υλοποιήθηκε με hardcoded paths, αλλά αξιοποιήθηκε η βιβλιοθήκη **pathlib** της Python για τον δυναμικό εντοπισμό του τρέχοντος καταλόγου εκτέλεσης (working

directory). Το σύστημα κατασκευάζει δυναμικά τη διαδρομή προς τον φάκελο των δεδομένων (BASE_DIR / "TrafficLabelling") εξαλείφοντας πιθανά path errors.

Βιβλιογραφία

[1] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, "Toward generating a new intrusion detection dataset and intrusion traffic characterization," in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, vol. 1, 2018.
https://www.semanticscholar.org/paper/Toward-Generating-a-New-Intrusion-Detection-Dataset-Sharafaldin-Lashkari/a27089efabc5f4abd5ddf2be2a409bff41f31199

[2] "TwinGuard: A Supervised Machine Learning Framework for DoS Attack Detection in IoT-Enabled Digital Twins Using Random Forest and Feature Selection Optimization," *ResearchGate*.
https://www.researchgate.net/publication/397320994_TwinGuard_A_Supervised_Machine_Learning_Framework_for_DoS_Attack_Detection_in_IoT-Enabled_Digital_Twins_Using_Random_Forest_and_Feature_Selection_Optimization

[3] E. Ologunde, "Explainable AI for SOC Analysts: A Framework for Bridging Model Output and Operational Trust Through Counterfactual and Causal Explanations," *ResearchGate*, 2026.
https://www.researchgate.net/publication/404704611_Explainable_AI_for_SOC_Analysts_A_Framework_for_Bridging_Model_Output_and_Operational_Trust_Through_Counterfactual_and_Causal_Explanations

[4] S. M. Lundberg et al., "From local explanations to global understanding with explainable AI for trees," *Nature Machine Intelligence*, vol. 2, no. 1, 2020.
https://www.researchgate.net/publication/333077391_Explainable_AI_for_Trees_From_Local_Explanations_to_Global_Understanding

[5] G. Apruzzese, M. Colajanni, L. Ferretti, A. Grosso, and M. Marchetti, "On the effectiveness of machine and deep learning for cyber security," in *10th International Conference on Cyber Conflict (CyCon)*, 2018.
https://www.researchgate.net/publication/326276522_On_the_effectiveness_of_machine_and_deep_learning_for_cyber_security

[6] N. Martins, J. M. Cruz, T. Cruz, and P. H. Abreu, "Adversarial machine learning applied to intrusion and malware scenarios: a systematic review," *IEEE Access*, vol. 8, 2020.
https://www.researchgate.net/publication/339349232_Adversarial_Machine_Learning_Applied_to_Intrusion_and_Malware_Scenarios_A_Systematic_Review

[7] G. Apruzzese, M. Andreolini, M. Marchetti, A. Venturi, and M. Colajanni, "DReLAB – Deep REinforcement Learning Adversarial Botnet: A benchmark dataset for adversarial attacks against botnet Intrusion Detection Systems
," *IEEE Communications Surveys & Tutorials*, 2022.
https://www.researchgate.net/publication/346781641_DReLAB_-_Deep_REinforcement_Learning_Adversarial_Botnet_A_benchmark_dataset_for_adversarial_attacks_against_botnet_Intrusion_Detection_Systems

[8] D. Sculley et al., "Hidden technical debt in machine learning systems," in *Advances in Neural Information Processing Systems*, vol. 28, 2015.
https://www.researchgate.net/publication/319769912_Hidden_Technical_Debt_in_Machine_Learning_Systems

[9] Canadian Institute for Cybersecurity, "CIC-IDS2017 Intrusion Detection Evaluation Dataset." [Online]. Available: https://www.unb.ca/cic/datasets/ids-2017.html

[10] I. Ahmad, M. Basheri, M. J. Iqbal, and A. Raheem, "Performance comparison of support vector machine, random forest, and extreme learning machine for intrusion detection," *King Abdulaziz University*.
https://www.researchgate.net/publication/325459405_Performance_Comparison_of_Support_Vector_Machine_Random_Forest_and_Extreme_Learning_Machine_for_Intrusion_Detection

[11] "Overview and Exploratory Analyses of CICIDS 2017 Intrusion Detection Dataset," *ResearchGate*.
https://www.researchgate.net/publication/373994633_Overview_and_Exploratory_Analyses_of_CICIDS_2017_Intrusion_Detection_Dataset

[12] D. Arp et al., "Dos and Don'ts of Machine Learning in Computer Security," in 31st USENIX Security Symposium (USENIX Security 22), 2022.
https://www.usenix.org/conference/usenixsecurity22/presentation/arp

[13] B. Schölkopf, J. C. Platt, J. Shawe-Taylor, A. J. Smola, and R. C. Williamson, "Estimating the Support of a High-Dimensional Distribution," *Neural Computation*, vol. 13, no. 7, pp. 1443–1471, 2001.
https://www.researchgate.net/publication/220499623_Estimating_the_Support_of_a_High-Dimensional_Distribution

[14] M. M. Breunig, H.-P. Kriegel, R. T. Ng, and J. Sander, "LOF: identifying density-based local outliers," in *Proceedings of the 2000 ACM SIGMOD International Conference on Management of Data*, 2000, pp. 93–104. https://www.researchgate.net/publication/221214719_LOF_Identifying_Density-Based_Local_Outliers

[15] S. Garcia, M. Grill, J. Stiborek, and A. Zunino, "An empirical comparison of botnet detection methods," *Computers & Security*, vol. 45, 2014. https://www.researchgate.net/publication/262921640_An_Empirical_Comparison_of_Botnet_Detection_Methods

[16] A. Shiravi, H. Shiravi, M. Tavallaee, and A. A. Ghorbani, "Toward developing a systematic approach to generate benchmark datasets for intrusion detection," *Computers & Security*, vol. 31, no. 3, 2012. https://www.researchgate.net/publication/257006500_Toward_developing_a_systematic_approach_to_generate_benchmark_datasets_for_intrusion_detection

[17] L. Grinsztajn, E. Oyallon, and G. Varoquaux, "Why do tree-based models still outperform deep learning on typical tabular data?," in *Advances in Neural Information Processing Systems (NeurIPS)*, 2022. https://www.researchgate.net/publication/401451156_Why_Do_Tree-Based_Models_Still_Outperform_Deep_Learning_on_Typical_Tabular_Data